IEEE Access
Multidisciplinary | Rapid Review | Open Access Journal

Date of publication xxxx 00, 0000, date of current version xxxx 00, 0000.

Digital Object Identifier 10.1109/ACCESS.2024.0429000

Law, Policy, and Governance of the AI Ecosystem for Human Control: The Human-Centric AI Governance and Continuous Oversight Framework (HACOF)

MUHAMMAD FAISAL LAIQ[1]
[1](e-mail: shmlaiq@gmail.com; ORCID: 0009-0007-5779-9836)
Corresponding author: Muhammad Faisal Laiq (e-mail: shmlaiq@gmail.com).

This work received no external funding or institutional support.

ABSTRACT Artificial intelligence (AI) systems, autonomous agents, and intelligent bots act faster than human supervisors can inspect them. We propose the Human-Centric AI Governance and Continuous Oversight Framework (HACOF), an integrated model combining legally enforceable AI policies, technical safety controls, independent supervisory AI agents, real-time behavioral monitoring, automated containment mechanisms, and accountable human governance. AI systems operate within explicitly defined legal, ethical, operational, and technical boundaries, while dedicated supervisory agents continuously evaluate AI activities, identify policy violations, detect emerging risks, and initiate proportionate protective actions. Authority flows from human rights and law, through institutional policy and technical guardrails, to supervisory agents that monitor compliance across the AI lifecycle and are themselves governed; high-risk violations trigger immediate containment, and ambiguous or consequential decisions go to authorized human reviewers. Because absolute prevention cannot be guaranteed, HACOF rests on defense-in-depth, independent verification, resilience, and continuous improvement, aiming to reduce the likelihood, severity, and duration of harm while preserving innovation, autonomy, privacy, and due process. We decompose the state capacity to require and verify such oversight into four pillars: boundary-setting, incentive-steering, human-in-the-loop (HITL) regulatory capacity, and algorithmic auditing access. All four concentrate in the United States, European Union, and China. We use Pakistan's 2025 National AI Policy to show what a low-capacity state can mandate. A prototype passes its self-tests, and in a simulation with assumed detector rates HACOF cuts residual harm about elevenfold versus a baseline. As a policy-oriented reference model, HACOF integrates established runtime-enforcement and AI-control techniques into an enforceable, auditable, contestable form.

INDEX TERMS AI alignment, AI governance, AI guardrails, AI monitoring, AI risk management, AI safety, algorithmic auditing, automated enforcement, autonomous agents, human oversight, regulatory capacity, responsible AI, technology policy

I. INTRODUCTION

ARTIFICIAL intelligence is moving from systems that mainly generate text and images to autonomous agents that execute workflows, call external services, write and run software, retrieve information, coordinate other agents, and change things in the physical and financial world. The benefits are real and broad — in science, education, healthcare, cybersecurity, industrial automation, public administration, and economic development. So are the risks: an agent can act outside the purpose it was authorized for, breach a policy it was never technically prevented from breaching, be steered into serving a malicious actor, or take a consequential decision no person reviewed.

The core difficulty is one of rate. Agents act continuously, at machine speed, and in the thousands or millions; no team of human supervisors, however well trained, can inspect every interaction, decision, transaction, or autonomous action as it happens. Governance that rests only on written ethical principles, voluntary commitments, or occasional human inspection therefore governs very little of what agents do. Its

requirements have to be turned into operational controls that are enforced throughout the AI lifecycle — at the point where an agent acts, not in a document the agent never reads.

This paper's operational proposition can be stated in one sentence.

> **Proposition —** AI systems should operate inside a governance environment that is legally authorized and technically enforced, in which independent supervisory mechanisms watch their activity continuously, prevent or contain prohibited behavior, and themselves answer to accountable human oversight.

The aim is not to abolish AI autonomy or to forbid legitimate experimentation. It is to keep autonomy bounded by purposes people have defined, by applicable law, by safety requirements, and by the protection of human welfare. To that end we introduce the Human-Centric AI Governance and Continuous Oversight Framework (HACOF). It brings six things into one architecture. Policy is enforceable by law, safety controls are built into the technical environment, and supervisory agents are independent of the agents they watch. Behavioral monitoring runs as actions happen, containment can trigger without waiting for a person, and human governance remains accountable for all of it. HACOF starts from the assumption that some harmful actions will get through, so it is built to fail safely, with no promise of perfection (Section V.C sets out the four principles this implies).

The operational question has an institutional twin. In 2025, Pakistan published a National AI Policy, joining a list of more than 70 countries that have now issued some form of national AI strategy [1]–[3]. The compute on which frontier models are trained is concentrated in a handful of countries, overwhelmingly the United States and China, and in a few hyperscale providers [4]; Pakistan is not among them. None of the firms whose products the policy will eventually need to regulate are headquartered there. That asymmetry is not a Pakistan-specific curiosity. It is the ordinary condition for most of the governments now writing AI policy, yet the dominant framing in both popular and scholarly discussion of AI governance treats regulatory capacity as a matter of political will — write the law, stand up the agency, and sovereignty over AI deployment follows. It does not follow automatically, and this paper explains why.

Meaningful human control over an AI system requires more than a legal text that says humans remain in charge. It requires the practical ability to act on that text: to define what a system may not do and have the definition enforced; to steer development toward applications a society wants, not merely to prohibit; to staff institutions that can keep pace with systems that change faster than legislative cycles; and, in the pillar most policy documents skip entirely, to look inside a deployed model and verify that what the vendor claims about it is true. We call these four requirements boundary-setting, incentive-steering, human-in-the-loop (HITL) regulatory capacity, and algorithmic auditing access. Each one sounds like a policy choice. In practice, each is bottlenecked by resources (compute, capital, technical personnel, and access to training data and model internals) that are not evenly distributed across states.

This paper's central claim is structural, not merely descriptive. The United States, the European Union, and the People's Republic of China are, today, the only three jurisdictions where all four pillars exist together, and that clustering is not an artifact of those three choosing to regulate first. It follows from where the compute lives, where the capital that funds frontier labs is raised, and where the technical staff who can audit a transformer-scale model's behavior are trained and employed. A government elsewhere can pass a law naming any of the four pillars. Passing the law does not generate the underlying capacity the law presupposes.

How control is enforced where an agent acts, and which governments can require and verify that enforcement, are the paper's two halves. HACOF is where they meet. Its enforcement power has to derive from law, so its reach is bounded by the capacity of the state whose law it is. Three distinctions are kept explicit throughout. Safety mechanisms inside one system are different from policing across systems; a monitor that detects a violation is different from an enforcement point with the authority to prevent it; and continuous oversight of AI activity is different from unrestricted surveillance of the people who use AI.

The contributions of this paper are as follows.

- Our principal contribution is HACOF, a deployment-level reference model that specifies the six components introduced above as one system. It assembles techniques already known from runtime enforcement and AI control under a legal chain of authority that begins with rights and statute and ends at the supervisory agents, with organizational policy and technical guardrails as its intermediate links. It adds a governance regime and binding privacy limits for the supervisory agents themselves, and it requires those supervisors to be diverse in method because model errors correlate. Each component is mapped onto the four pillars to separate what a state must operate itself from what it can simply require of deployers. The paper traces one illustrative incident through every step of its operational lifecycle (Section V.L), specifies an evaluation protocol, and reports a working prototype of its enforcement plane together with a simulation that checks its logic and shows how its bounds behave (Section VII.D). A cell-by-cell comparison with twelve prior frameworks and instruments (Table 2) shows which parts it borrows and which it adds; no new technical architecture is claimed.
- To locate where HACOF's legal authority can come from, we propose a four-pillar framework — boundary-setting, incentive-steering, HITL regulatory capacity, and algorithmic auditing access — that decomposes "meaningful human control over AI" into components that can each be independently assessed, and we give a

formal argument for why these four components do not substitute for one another.
- We map the three current major-power regulatory frameworks, namely the European Union's Artificial Intelligence Act (EU AI Act), the United States' executive-and-agency framework, and China's algorithm-governance regime, against the four pillars, establishing them as the empirical baseline against which the rest of the paper measures capacity elsewhere. We also name three concrete legal mechanisms that would need to exist in new law or policy to close the gap: a compute-governance/licensing regime, a binding technology-transfer obligation, and a coalition-extended cross-border audit right.
- We provide a detailed case study of Pakistan's 2025 National AI Policy against this framework, including a funding-to-GDP comparison against frontier labs' capital raises and the labor-market exposure of entry-level work, and draw out what the resulting account implies for the broader class of non-major economies, closing with a prioritized research agenda.

The remainder of the paper proceeds as follows. Section II positions this work against five adjacent literatures: AI existential-risk and safety-warning scholarship, major-power regulatory-framework literature, technical self-governance mechanisms, Global South AI-governance scholarship, and runtime oversight of AI agents. Section III maps the three major powers' current frameworks as a factual baseline. Section IV presents the four-pillar framework in detail, pillar by pillar, with an account of why capacity concentrates where it does, and closes by naming three concrete new-law-and-policy mechanisms that would address it directly. Section V moves from the state to the deployment, presenting HACOF and mapping it back onto the four pillars. Section VI gives a formal analysis of the framework, then applies it to Pakistan as a case study, compares the resulting profile against the three major powers, and asks which HACOF controls Pakistan could mandate today. Section VII specifies how HACOF should be tested before anyone relies on it. Section VIII sets out its limitations. Section IX answers the question the paper opened with and proposes a research agenda ordered by urgency.

II. RELATED WORK

A. AI EXISTENTIAL-RISK AND SAFETY-WARNING LITERATURE

A substantial literature argues that advanced AI poses risks severe enough to warrant coordinated, possibly binding international control — from calls by AI-lab leaders for an international agency to govern superintelligence [5] to signed public statements from AI researchers and executives calling for the technology to be treated as a societal-scale risk alongside pandemics and nuclear weapons [6]. This literature is almost entirely about *whether* control is necessary and *what* a catastrophic failure would look like. It says comparatively little about *who* can exercise control once the need is granted. A government convinced by every argument in this literature still cannot act on that conviction without the four pillars described here. The safety-warning literature assumes an implementing actor exists; it does not examine whether that actor has the capacity the warning presupposes. That is the gap the four-pillar framework fills for the governance side of the argument. Later treatments extend the risk argument into proposed international coordination mechanisms, such as compute-governance regimes and licensing schemes for frontier training runs; these implicitly require the very HITL and auditing capacity we show to be concentrated in three jurisdictions, without stating that requirement as a precondition for the coordination mechanism to function [7].

B. MAJOR-POWER AI REGULATORY FRAMEWORKS AS LITERATURE

A second, much more concrete literature analyzes instruments such as the EU AI Act's risk-tiered structure [8], the United States' executive-order-and-agency-guidance approach to AI oversight [9], and China's algorithm-registration and generative-AI content rules [10]. Each strand is detailed on its own jurisdiction and largely silent across jurisdictions. Where the three regimes are compared at all, the comparison is of regulatory *style* (risk-based, sectoral, or state-directed), not regulatory *capacity*. Style comparisons answer how each power chose to regulate. They do not answer whether a government without the EU's technical staff, the United States' compute base, or China's state-directed capital could adopt any of the three styles and get the same result. A related strand examines the codes of practice the Act provides for, voluntary instruments meant to operationalize its general-purpose-model provisions [8]. Even this instrument, aimed at easing compliance, presupposes a technical drafting capacity on the regulator's side that the literature in this subsection assumes without interrogating. Section III uses the same three frameworks as a factual baseline, but asks the capacity question the comparative-style literature leaves open.

C. TECHNICAL SELF-GOVERNANCE MECHANISMS

A third literature treats model-level technical mechanisms as governance in their own right: Constitutional AI, which trains a model against an explicit written set of principles, reducing its reliance on human-labeled preference data [11]; a lab's own Responsible Scaling Policy, a self-imposed commitment to graduated safety testing that one major lab's chief executive has described as ''not intended as a substitute for regulation, but rather a prototype for it'' [12]; algorithmic auditing frameworks for bias and fairness assessment [13]–[15]; and model cards or system cards documenting a model's intended use and known limitations [16]. These mechanisms are real engineering contributions to safety. They are also, without exception, mechanisms controlled by the lab that trains the model. A constitution is written by the lab. An audit, when one is published, is run or commissioned by the lab or by a regulator inside the lab's home jurisdiction. Self-governance of this kind answers a different question than the one asked

here. It shows what a capable actor can build into its own system, not what capacity an external government needs to verify that the system behaves as claimed. Nothing in this literature addresses external, cross-border audit access (pillar four of our framework) as a distinct governance problem. Even the strongest technical self-governance commitments remain voluntary disclosures. A lab publishing a detailed system card has chosen to publish it, and the same lab retains full discretion over what the card omits, a discretion no external government currently has standing to challenge [16].

D. GLOBAL SOUTH AND DEVELOPING-ECONOMY AI GOVERNANCE LITERATURE

A fourth and comparatively thin literature examines AI governance from the vantage point of economies outside the three major powers. Its institutional instruments include the African Union's Continental AI Strategy [17], UNESCO's Recommendation on the Ethics of Artificial Intelligence as a soft-law instrument aimed at broad international adoption [18], and the Global Partnership on AI's multi-stakeholder structure [19]. Its scholarly strand makes the normative case more directly. Arun's case-study survey argues AI governance frameworks designed around Global North assumptions systematically mis-fit Global South deployment contexts [20]. Mhlambi critiques the rationality-centered foundations of Western AI ethics and proposes a relational alternative grounded in Ubuntu personhood [21]. Ayana et al. supply the closest existing empirical analog to our comparative method, assessing the state of decolonized AI governance institutions across Sub-Saharan Africa [22]. This literature correctly diagnoses unequal participation. It is weaker on mechanism. Soft-law instruments like the UNESCO recommendation are explicitly non-binding, and multi-stakeholder bodies like the Global Partnership on AI include non-major economies as participants in a forum that has no enforcement authority over any firm's deployed model. Participation in a forum is not the same as rule-making capacity. Our contribution relative to this fourth strand is to decompose ''unequal participation'' into the four specific capacity deficits that produce it, and to illustrate that decomposition with one detailed national case alongside the cross-country picture.

E. RUNTIME OVERSIGHT AND CONTROL OF AI AGENTS

A fifth literature starts where the other four stop: after a model has been deployed with tools, credentials, and permission to act. Greenblatt et al. treat the problem adversarially. Their setting assumes the capable model might be working against its operator. They ask how much a weaker model the operator does trust can catch before harm occurs when backed by a scarce budget of trusted high-quality labor, modeled in their experiments as auditing 2% of tasks [23]. Shavit et al. cover similar ground as a set of operating practices for agentic systems — constraining the action space or requiring approval for some actions, automatic monitoring, attributability of actions, and keeping the agent interruptible [24]. Chan et al. argue for visibility into deployed agents through agent identifiers, real-time monitoring, and activity logs, and are candid that each measure raises privacy concerns of its own [25]. Kolt reads the same agents through agency law and the principal–agent problem [26]. At the enforcement end sit classifier safeguards that screen a model's inputs and outputs [27], [28] and programmable rails wrapped around a model at runtime [29]. A newer line moves from classifiers to whole agents and enforcement layers. Guard agents check another agent's actions against rules, in ShieldAgent's case rules extracted from policy documents [30], [31]; AgentSpec gives developers a rule language enforced at the agent's runtime [32]; networks of ''sentinel'' agents with a coordinator able to quarantine misbehaving agents have been proposed for multi-agent systems [33]; and runtime governance layers with graduated enforcement and containment already exist as preprints [34], [35]. Layered reference architectures stack these guardrails [36], Koch maps the main governance standards onto control layers that run from governance objectives down to runtime mediation [37], and Singapore's agentic-AI governance framework already asks for scoped agent authorization, human checkpoints for high-stakes actions, and continuous monitoring [38]. The underlying engineering idea is older still: runtime assurance, in which a simple verified component keeps final authority over a complex unverified one [39], [40]. The threat they chase is concrete. Instructions planted in content an LLM-integrated application retrieves can hijack that application against its own user [41].

This is the closest technical neighbor to the architecture in Section V, and HACOF borrows from it openly. Nearly every component of HACOF has a precedent somewhere in it. One assumption runs through almost all of it. Whoever already operates the system also operates the oversight — a lab, or a deploying firm with engineers on payroll. With the partial exception of the public frameworks, nobody here asks which governments can require such oversight, or verify that it runs as described once required. That is the capacity question of Section IV, and it is absent. A second gap is narrower. In trusted monitoring the monitor is trusted by construction, meaning it is assumed not to be attempting the subversion it watches for. Where an untrusted model does the monitoring, the safeguard is an anti-collusion technique inside the protocol [23]. That is a sound modeling choice for a research protocol and a weak one for an institution. The works cited here treat the monitor as an engineering component; they say little about who audits the monitors as an institutional matter, who may suspend one that misbehaves, what personal data a monitor may collect, or which legal authority its interventions rest on.

Read together, these five literatures diagnose the same absence from five different directions. The safety-warning literature worries about catastrophic failure without asking who can prevent it locally. Comparative work on regulatory frameworks documents how three jurisdictions regulate but never asks why only three can. Studies of technical self-governance show what a capable lab can build into its own system without addressing who outside that lab can verify

it. The Global South literature names the resulting inequality without decomposing what, specifically, would need to change. And the runtime-oversight literature builds the machinery of control while leaving open who can require it and who watches the watchers. The framework developed here holds all five observations inside a single structure. Until now they have been separate conversations that rarely cite one another.

III. BACKGROUND: CURRENT MAJOR-POWER FRAMEWORKS

The three jurisdictions this paper treats as currently possessing cross-pillar governance capacity are the European Union, the United States, and China. None of the three frameworks below is complete or uncontested even inside its own jurisdiction; each is sketched here only as the baseline the rest of the paper measures capacity against.

A. THE EUROPEAN UNION'S AI ACT

The EU AI Act establishes a risk-tiered regulatory structure with four bands — unacceptable risk (prohibited outright), high risk (subject to conformity assessment, documentation, and human-oversight requirements before market entry), limited risk (subject to transparency obligations), and minimal risk (largely unregulated) [8]. A separate track governs general-purpose AI (GPAI) models, with additional obligations triggered once a model's training compute crosses a defined threshold, on the premise that systemic risk scales with scale itself [8]. Enforcement sits with a dedicated EU AI Office alongside national market-surveillance authorities in each member state [8]. The Act is, on paper, the most comprehensive boundary-setting instrument currently in force anywhere. It is also the slowest-moving of the three frameworks, with staggered implementation timelines running years past the Act's initial adoption [8], and in July 2026 an amending regulation postponed the high-risk obligations to December 2027 for stand-alone high-risk systems and August 2028 for those embedded in regulated products [42] — a genuine trade-off between comprehensiveness and speed that Section IV returns to.

The Act's extraterritorial reach matters because it is the single clearest illustration in this entire paper of what boundary-setting leverage looks like in practice. A vendor headquartered in the United States with no EU office and no EU employees is still bound by the Act's obligations the moment it sells, or makes available, a covered system to an EU user [8]. No comparable mechanism protects a market the size of Pakistan's, which is why Section IV.A treats market size itself, not legal drafting quality, as the operative variable.

B. THE UNITED STATES' FRAMEWORK

The United States has no single AI statute comparable to the EU AI Act, and its executive-branch approach has reversed direction once already within three years. Executive Order 14110 (2023) set agency-level risk-management expectations under the prior administration [43]; it was revoked on the first day of the following administration and replaced by Executive Order 14179 (January 2025), which reoriented federal policy around removing regulatory barriers to US AI development [44]. The most recent and currently binding action, Executive Order 14365 (December 2025), goes further. It directs the Department of Justice to stand up a task force to challenge *state-level* AI laws deemed inconsistent with federal policy [9] — an explicit federal move to preempt the state legislation that had been filling the gap left by the absence of a federal statute. Alongside this sequence, the National Institute of Standards and Technology's (NIST) AI Risk Management Framework has remained in place as voluntary technical guidance throughout both administrations, the one point of continuity in an otherwise reversed federal posture [45]. The honest characterization of the US framework by late 2025 is not ''comprehensive oversight achieved through accretion'' but **deliberately light-touch and actively preemptive of stricter sub-national regulation**. That is a policy choice, made by a government that has the capacity. We return to it in Section IV, because it shows a major power choosing minimal binding regulatory capacity federally despite possessing the compute, capital, and technical staff that the following sections argue most other governments lack entirely.

The fragmentation has a specific institutional cause. No single US federal agency holds general-purpose authority over AI the way the EU AI Office does, so oversight is distributed across existing sectoral regulators (consumer-protection, financial, and health regulators among them), each applying AI-specific guidance on top of a pre-existing statutory mandate never written with transformer-scale models in mind. This produces genuine technical depth within each sector and genuine gaps between sectors, a trade-off the EU's single horizontal statute was explicitly designed to avoid.

C. CHINA'S FRAMEWORK

China's algorithm-governance regime centers on mandatory registration of recommendation and generative algorithms with the Cyberspace Administration of China (CAC), combined with specific content and labeling rules for generative AI services made available to the public [10]. The regime is state-directed rather than market-mediated. The same state that regulates AI development also steers investment into it, a role China's 2017 national AI development plan made explicit by committing government funds and channeling market capital toward AI [46]. This dual role, as regulator and primary capital allocator for the same technology, has no equivalent in the EU or US frameworks, and it is the clearest illustration in this section of why ''regulatory capacity'' and ''incentive-steering capacity'' are not independent of each other in practice, even though we treat them as analytically distinct pillars.

D. SYNTHESIS: WHAT THE THREE FRAMEWORKS SHARE, AND WHAT NONE OF THEM ADDRESSES

Read side by side, the three frameworks share more than their differing political origins suggest. Each relies on a domestic

pool of technical staff close to the industry it regulates: the EU AI Office, NIST's advisory apparatus, and China's CAC technical reviewers alike. Each backs its rules with a lever unavailable to a government outside the three jurisdictions: market size for the EU, home-jurisdiction authority over the largest labs for the US, and direct state ownership of capital and infrastructure for China. And none of the three frameworks includes a formal mechanism for extending its own audit or enforcement capacity to a government that lacks one. The EU AI Act regulates vendors selling into the EU, not vendors' conduct inside a third country that has no equivalent statute of its own.

This last point is easy to miss. It is not that the three major powers have excluded other governments from AI governance by design. Their frameworks were built to solve a domestic problem (protecting the EU single market, managing US national-security and innovation trade-offs, maintaining Chinese Communist Party oversight of information systems), and none of the three had an internal reason to build an export mechanism for governance capacity itself. The absence is a byproduct of each framework's origin; nothing suggests it was designed to keep other governments out, which matters directly for Section IX's argument that the fix is closer to new infrastructure than to persuading any of the three to share what they already have.

IV. PROPOSED FRAMEWORK: FOUR PILLARS OF AI GOVERNANCE CAPACITY

Meaningful human control over AI requires joint capacity across four pillars. Fig. 1 shows the structure. Each pillar feeds a single governance outcome, and none substitutes for the others. This section defines each pillar's theoretical requirement, then explains why the resources that generate real-world capacity in that pillar (compute, capital, institutional and technical expertise, and data access) concentrate in the three jurisdictions described in Section III.

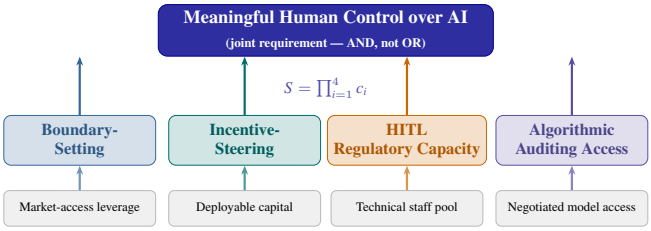


FIGURE 1. The four-pillar framework. Each pillar rests on a distinct resource base (bottom row) and jointly feeds a single governance outcome (top). The product aggregation $S = \prod c_i$, formalized in Section VI.A, reflects that a missing pillar is not compensated by strength in the other three.

A. BOUNDARY-SETTING

Boundary-setting is what lets a government forbid a specific deployed behavior and make the prohibition stick against whoever operates the system. Writing the prohibition into statute is only the first step. The theoretical requirement is straightforward. A limit that cannot be enforced works only as a request. Enforcement requires legal authority over the entity operating the system. That is trivial when the operator is domiciled inside the regulator's jurisdiction and close to impossible when it is not.

This is where boundary-setting capacity concentrates sharply. The EU AI Act can compel compliance from any firm selling into the EU single market regardless of where that firm is headquartered, because market access itself is the enforcement lever [8]. A government without a market of comparable size has no equivalent lever: a firm that ignores its AI rules loses access to a market it may not have prioritized in the first place. Pakistan's IT and IT-enabled-services export sector, valued at a record approximately $4.6 billion annually [47], is not large enough to make compliance with a Pakistan-specific AI rule a commercial priority for a frontier lab headquartered in California or Beijing — and Pakistan's whole economy is roughly one-fiftieth the size of the EU's, a gap we derive from the two economies' GDP; no single source states it. Boundary-setting without market leverage is, in practice, advisory.

A second, less obvious resource requirement sits underneath boundary-setting: the ability to detect a violation in the first place. A prohibition a regulator cannot monitor is unenforceable even where market leverage exists, because enforcement presupposes evidence. Monitoring a deployed AI system at scale requires either direct API-level telemetry access, which vendors control, or independent technical means of probing system behavior in production — both of which circle back to the data-access and technical-personnel constraints discussed under the remaining three pillars. Boundary-setting, in other words, is never purely a legal capacity; it is a legal capacity riding on top of a detection capacity that the framework treats as shared infrastructure across all four pillars.

B. INCENTIVE-STEERING

Incentive-steering is the capacity to pull AI development toward applications a society wants — public-health diagnostics, agricultural forecasting, language tools for under-resourced languages — instead of only writing rules against the uses it fears. This pillar is frequently absent from governance discussions entirely, which is itself a symptom of the capacity gap at issue. Restriction is cheap to legislate, while steering requires money.

Incentive-steering requires capital deployed at a scale that moves a market, and that capital exists almost exclusively inside the three major powers. The United States' CHIPS and Science Act directed tens of billions of dollars toward domestic semiconductor and AI-adjacent capacity [48]. China's state-directed AI industrial policy operates at a comparable or larger scale through a different mechanism, discussed in Section III.C. The EU's funding instruments for AI research and deployment, while smaller than either, still dwarf what a mid-sized economy can allocate [49]. A government that cannot move capital at this scale cannot steer a market; it can only hope the market steers itself toward applications

that happen to be useful locally, and that hope is frequently disappointed, because frontier labs optimize for the markets that fund them.

Compute is a second, distinct resource constraint on incentive-steering, separate from capital itself. A government that wants to seed domestic applications built on open-weight models, so as not to depend entirely on API access to foreign-hosted frontier systems, needs sovereign compute capacity to fine-tune and serve those models reliably [50]. Capital without compute buys dependence on the same three jurisdictions already identified as dominant; a funding line that cannot also buy or build local compute access steers nothing, because the underlying infrastructure the funded projects run on remains rented from elsewhere.

NVIDIA's own account of where AI value accrues makes the same point from the supply side. Its chief executive has described the AI ecosystem as a five-layer stack of energy, chips, infrastructure, models, and applications, each layer reinforcing the ones above it [50]. A government without incentive-steering capacity can, at best, participate at the top layer, building applications on infrastructure, chips, and energy supplied entirely by others; it has no purchase on the three layers beneath, which is where the resource-concentration argument places the United States, the European Union, and China. The scale at which capital moves through that stack has grown more than thirtyfold in about six years: NVIDIA's market capitalization stood near $144 billion at the start of 2020 and reached $5.5 trillion in mid-2026 [51], a single firm's valuation increase alone exceeding ten times Pakistan's national GDP. A funding line calibrated to a national budget cannot move a market calibrated to numbers like these; it was never going to.

C. HUMAN-IN-THE-LOOP (HITL) REGULATORY CAPACITY

HITL regulatory capacity is the existence of institutions staffed with people who understand how modern AI systems fail, and who can intervene at the speed of deployment cycles, a speed legislative cycles cannot match. The theoretical requirement here is specific and often underestimated. A regulator who cannot read a model's evaluation report, or who takes eighteen months to review a system update that ships every six weeks, is not exercising oversight — it is rubber-stamping with a delay.

This pillar is bottlenecked by technical personnel, and technical personnel capable of evaluating frontier-scale systems are concentrated in the same three jurisdictions that train the systems. The EU AI Office employs more than 140 staff, over 40 of them in its AI safety unit, most with technical backgrounds [52]. NIST's AI Risk Management Framework work similarly draws on a dense US domestic pool of machine-learning researchers [45]. By the AI Index's institutional-affiliation measures, AI research talent is concentrated overwhelmingly in these three jurisdictions [53]. A finance ministry can create a regulatory body on paper in a week. It cannot create the pool of people who can staff it in a week, or, in most cases, in a decade.

HITL regulatory capacity also depends on data access in a way that is easy to overlook. A regulator cannot evaluate whether a deployed model behaves safely on a population it was never tested against without access to representative local data for that population. A model evaluated exclusively on English-language, US- or EU-sourced benchmark data may behave differently on Urdu-language queries or Pakistan-specific use cases, and no amount of regulatory staffing substitutes for the local evaluation datasets needed to test for that gap [53]. Building and maintaining such datasets is itself a resource-intensive undertaking that again favors jurisdictions with existing data-infrastructure investment.

D. ALGORITHMIC AUDITING AND SELF-MONITORING ACCESS

Algorithmic auditing access means having real standing to open up a model someone else trained (its data provenance, its weights, its behavior under adversarial probing) without taking the vendor's self-reported documentation on faith. This is the pillar most absent from public AI-governance discourse, and the one we treat as the hardest to acquire externally, because it depends on access the vendor controls.

The risk this pillar exists to guard against has a documented historical precedent outside AI entirely. In 1904, a horse named Hans became famous across Germany for apparently solving arithmetic by tapping its hoof, and an official commission of veterinarians, trainers, and scientists examined the horse, found no evidence of deliberate fraud, and concluded the animal was genuinely performing the calculations. A further investigation by psychologist Oskar Pfungst later established the opposite: the horse had no arithmetic ability at all, and was instead reading involuntary, unconscious postural cues from its questioner, stopping exactly when the asker's body language signaled the correct tap count had been reached — and failing completely once the questioner's cues were hidden from the horse's view [54]. The commission's error was not carelessness; it was testing the horse under conditions that left the actual causal mechanism invisible to the test. A government evaluating a deployed AI system through a vendor-curated demonstration is in exactly the commission's position relative to the horse, not Pfungst's: it can observe the output, but not the mechanism producing it, and a system's apparent capability can be a property of infrastructure and scaffolding the evaluator never sees, rather than of the system being evaluated. Algorithmic auditing access is the institutional equivalent of being allowed to run Pfungst's follow-up test instead of only watching the horse perform.

The normal path to audit access runs through a negotiated agreement: a regulator inside the vendor's home jurisdiction requests structured access under statutory authority, and the vendor complies because refusal carries a market-access penalty under Section IV.A's boundary-setting lever. The conflict path arises when the requesting government has no such lever: the vendor can offer a sandboxed, limited-scope demonstration instead of genuine model access. The fallback for a government in that position is to rely on a mutual-

recognition arrangement with a major-power regulator that did obtain genuine access, or to rely entirely on the vendor's self-published model card — which is, definitionally, not an independent audit. Pakistan's National AI Policy does commit, in general terms, to impact assessments of high-impact systems and to a framework for third-party auditing of AI decision-making [1], but it contains no mechanism by which such an audit could be compelled from a foreign-hosted model provider. That is not a drafting oversight; no comparably sized non-major economy currently has the leverage to negotiate the normal path, and the policy's silence on enforcement against foreign providers reflects that fact; it is not a gap its authors could simply have written around.

E. PILLAR INTERDEPENDENCE: WHY THE FOUR DO NOT SUBSTITUTE FOR ONE ANOTHER

A natural objection to treating these four pillars as separate is that strength in one could compensate for weakness in another — that, for instance, enough incentive-steering capital could eventually buy the technical staff needed for HITL regulatory capacity, collapsing four pillars into one underlying resource: money. The objection has some force but ultimately fails, for a specific reason.

Capital converts into technical staff only on a multi-year timescale, because the relevant expertise does not exist as a purchasable commodity at the scale most governments would need. It belongs to people who can read a frontier model's training run, evaluate its failure modes, and know what a believable audit even looks like. A government can fund scholarships and fellowships; it cannot buy ten years of accumulated institutional experience inside a research and industry ecosystem that does not exist locally. Boundary-setting shows the same resistance to substitution from a different angle. No amount of domestic regulatory sophistication substitutes for market size, because enforcement against a foreign vendor runs through commercial leverage, which legal drafting skill cannot replace. Algorithmic auditing access resists substitution most starkly of the four, since it depends on a decision the vendor controls rather than a resource the regulating government can simply accumulate on its own schedule.

This interdependence argument is the qualitative version of the formal weakest-link aggregation developed in Section VI.A. It is presented here, ahead of the formal treatment, because the underlying intuition, that the four capacities complement one another and cannot stand in for each other, is doing real argumentative work on its own, independent of whether a reader accepts the specific mathematical model that follows.

F. TOWARD NEW LAW AND POLICY: THREE CONCRETE MECHANISMS

Diagnosing a capacity gap is not the same as specifying what should change in law and policy to close it. This subsection names three concrete mechanisms, each already proposed or precedented somewhere, and what adopting each would require and from whom.

A compute-governance or licensing regime for frontier training runs. The most developed version of this proposal combines domestic pre-approval regulation of training runs above a compute threshold with an international coordinating body, explicitly modeled on the International Atomic Energy Agency, to harmonize and monitor domestic regimes across jurisdictions, paired with a chip-export condition modeled on the Nuclear Non-Proliferation Treaty [7]. A related, narrower proposal would require large compute providers (the cloud and data-center operators frontier labs run on) to implement know-your-customer obligations analogous to banking, so that a concerning training run becomes visible, and interruptible, before it completes [55]. A third model borrows directly from pharmaceutical and aviation regulation: no frontier-scale system may be trained or marketed without prior regulator approval based on submitted safety evidence, mirroring how a new drug cannot be sold without a trial record a regulator has reviewed [56]. None of these three currently has the force of law anywhere. Adopting any of them requires the three jurisdictions that hold the compute, capital, and chip-export leverage described in Section IV.A–B to accept an external or shared oversight body with real standing over decisions each currently makes unilaterally, the kind of concession the framework predicts no major power has an unprompted incentive to make. The mechanism is specified; what is missing is the willingness to pay the political cost of adopting it.

A binding technology-transfer or capacity-building obligation attached to a major-power regulatory regime. This is the sharpest gap our review identified. The EU AI Act regulates third-country vendors selling into the EU extraterritorially, but contains no reciprocal obligation to build regulatory or technical capacity in the third countries whose markets those vendors also serve — the Act's third-country provisions are a compliance burden on vendors, not a capacity transfer to governments [8]. A real precedent for this kind of obligation exists in an adjacent domain: the Paris Agreement's Article 10, building on the UNFCCC's earlier technology-transfer commitment, requires support for developing-country parties and makes the standing UNFCCC Technology Mechanism serve the Agreement [57]. The precedent has its own weakness. Whether delivery has matched the commitment is disputed, and nothing in the article compels it. An AI-governance equivalent would not automatically avoid that same enforcement gap. It would, however, give non-major economies a textual obligation to invoke and negotiate against, which is strictly more leverage than current AI-governance instruments offer them: none at all.

A coalition-extended, mandatory, cross-border algorithmic audit right. Two real instruments currently point in this direction without yet reaching it. The Algorithmic Accountability Act, introduced repeatedly in the US Congress, would mandate impact assessments and a new enforcement

bureau, but it applies only domestically, with no extraterritorial reach for a government outside the United States [58]. The EU AI Act's Notified Body conformity-assessment mechanism is the clearest enacted example of mandatory, legally binding third-party algorithmic audit with extraterritorial force [8], although its application to high-risk systems has been deferred to December 2027 and August 2028 [42]; it exists to protect the EU single market, not to extend audit standing to a government that has no equivalent statute of its own. For a non-major economy, drafting a wholly new audit instrument alone is not a realistic near-term path, because such an instrument lacks enforcement teeth without market leverage (Section IV.A). The likelier route is to negotiate a coalition-based extension of an existing mechanism such as the EU's Notified Body system. The research agenda in Section IX ranks this coalition logic second, after audit-access mechanisms themselves.

These three mechanisms are not offered as a menu a single government can adopt unilaterally; each requires either a concession from a major power or a coalition a non-major economy cannot build alone. That constraint is the four-pillar finding again, stated as legislation. Where every major power declines, the fallback for a non-major economy is the deployer-side route of Section VI.D, which needs no concession from anyone.

V. HACOF: FROM GOVERNANCE CAPACITY TO CONTINUOUS OPERATIONAL OVERSIGHT

Section IV treats human control as a property of states, and Section VI tests that framing on Pakistan. The framing leaves one question untouched. Suppose a government does hold all four pillars. What, physically, stops a deployed AI agent from doing the thing the law forbids? This section proposes HACOF (Human-Centric AI Governance and Continuous Oversight Framework), a deployment-level reference model that answers that question in enough detail to be built and tested, and then shows which of its parts a weak regulator can require of deployers without building them itself. In short, the four pillars are what a state needs in order to require and verify HACOF-style controls; they are not what it needs in order to operate them.

A. WHY CAPACITY NEEDS AN OPERATIONAL LAYER

Take a firm whose written policy forbids its customer-service agent from disclosing client records, while the same agent holds read access to the whole client database, an outbound email tool, and permission to attach files. The policy exists. Nothing in the deployment enforces it. Whether the records stay inside depends on the model honoring an instruction — the very property that indirect prompt injection is built to defeat [41]. An agent told never to run destructive commands but handed an unrestricted shell is the same case in a different costume, and its safety depends entirely on how reliably the model follows instructions. OWASP's risk catalog names the general condition excessive agency: a model-driven component granted more functionality, permission, or autonomy than its task requires [59].

TABLE 1. The Five Problems and the HACOF Components That Address Them

Problem	Addressed by	Where
Translation	Layer 1 and 2: clause-traced authorization profiles; four boundary types	V.D
Continuity	real-time monitoring; per-agent baselines; supervisory agents	V.E, V.F
Prevention and containment	in-path guardrails; Prevent–Contain–Recover lifecycle; containment conditions	V.D, V.G
Accountability	audit plane; human roles; appeal path; regulator-facing records	V.H
Second-order risk	supervisor diversity; governance of the governors; privacy limits	V.E, V.I, V.J

The four pillars decide whether a state can write a rule and check that it is obeyed, but they say nothing about whether the rule ever reaches the point at which an agent acts. Closing that distance involves five separate problems, and Table 1 traces each to the parts of HACOF that address it:

1) *Translation* — legal and institutional requirements must become rules a machine can evaluate;
2) *Continuity* — agents act around the clock, faster than a person can review action by action;
3) *Prevention and containment* — a prohibited action should be stopped before it executes and, when that fails, contained quickly;
4) *Accountability* — each decision, violation, and intervention must leave evidence an outside party can check;
5) *Second-order risk* — whatever does the supervising can itself err, overreach, or be compromised.

The five interact, so solving one in isolation buys little. Monitoring without enforcement records an incident it cannot stop, enforcement without independent review restricts arbitrarily, and a human overseer who lacks either the evidence to judge or a working control to stop the system cannot in practice intervene.

HACOF brings together six working parts, each developed below. Its AI policies bind because they rest on law, and its technical safety controls sit outside the model; Section V.D covers both. Independent supervisory agents follow in Section V.E and real-time behavioral monitoring in Section V.F. Containment can act automatically, but only under the conditions stated in Section V.G. Section V.H sets out the human governance under which a named person answers for each consequential intervention. The limits an agent works within come from four sources, namely law, ethics, the deployer's operations, and the technical configuration, and Section V.D treats each separately. Within those limits, supervisors keep watch over what the agents do, flag breaches of policy, notice dangers that no rule yet names, and set off responses scaled

to the danger.

The governing structure is a hierarchy, and its order matters. Foundational human rights, together with whatever law applies, set the highest-level constraints. Institutional policies translate those constraints into rules specific enough to enforce. Technical guardrails stop unauthorized actions before they happen. Independent supervisory agents then watch for compliance across the whole AI lifecycle, from authorization through execution to review. A high-risk violation backed by clear evidence can trigger immediate technical containment; a decision that is ambiguous or consequential goes to an authorized human reviewer instead. Experimentation, research, and ordinary automation continue under HACOF, inside limits that people set and can inspect.

B. THREE DISTINCTIONS THAT BOUND THE CLAIM

Three distinctions recur through the rest of this section, and each one also limits what HACOF can be said to contribute.

Safety versus policing. Safety mechanisms act *within* a single system. Constitutional training shapes a model's dispositions against written principles [11], and guardrail classifiers screen what goes into and comes out of that one model [27], [28]. Policing acts *across* systems: something outside the governed agents checks whether their combined activity complies with rules that bind all of them. A well-aligned model can still be handed excessive privileges, and a well-run monitor cannot make a badly aligned model safe, so the two complement each other. HACOF claims neither half. What it adds, as the end of this subsection sets out, is a legal chain of authority that runs from statute down to specific enforcement points and extends to the supervisors themselves.

Detection versus prevention. A monitor can recognize suspicious activity. Only a component sitting on the execution path, with the authority to deny an action before it completes, can prevent it. A monitor that watches a copy of the traffic — *out-of-path* — can raise an alarm, revoke a credential after the fact, or isolate a workload, but it cannot guarantee that the first harmful action never happens. An *in-path* enforcement point can, for exactly the actions that are routed through it and for no others. The engineering precedent is runtime assurance in the Simplex style, where a complex, unverified controller runs alongside a simple, high-assurance controller, and decision logic switches control to the high-assurance controller when the system nears the edge of its safe envelope [39]. HACOF applies the same pattern to agents: the agent is the complex controller, the in-path gateway is the decision module, and the safe fallback is denial plus escalation to a human. Tables 7 and 8 and Fig. 3 mark which capabilities and responses depend on an in-path point, and Section V.K bounds what prevention can achieve when some actions bypass such points.

Oversight versus surveillance. HACOF monitors what AI systems do: tool calls, data access, credentials, delegation, transactions. It does not license unlimited observation of the people who use those systems or appear in their data. Privacy law, due process, and independent review bind the supervisory machinery exactly as they bind any other data processor, a point Section V.J develops.

The novelty claim is correspondingly modest. AI monitoring AI is established [23], [24], [33]; layered translation of governance standards into runtime controls has been sketched [37]; graduated enforcement for agents has been prototyped [34], [35]; explicit trust boundaries with policy decision and policy enforcement points are the core of zero-trust security architecture [60]; and the NIST AI Risk Management Framework already organizes organizational risk work into its Govern, Map, Measure, and Manage functions [45]. The AI RMF is process guidance for organizations, voluntary in the United States; HACOF is a runtime enforcement architecture that could implement parts of what Measure and Manage ask for, alongside the framework. HACOF is therefore offered as a reference model for policy makers, one that assembles these established techniques under legal authority, and not as a new technical architecture. What it adds is narrower: a legitimacy chain from statute to enforcement point, in which no automated component may originate a rule; a second-order governance regime and binding privacy limits for the supervisors themselves; a supervisor-diversity requirement grounded in evidence about correlated model errors; and the mapping to state capacity in Section V.M.

Table 2 sets these neighbors side by side. Read by row, it shows how much of HACOF already exists elsewhere; read by column, it shows where the gaps are. Several prior works, Shavit et al. and Chan et al. above all, raise the monitor's own reliability, its privacy cost, and the risk of monitors trained like the agents they watch as open concerns. None turns them into design requirements. The last four columns, where no prior row reaches a full mark, are where the contribution should be judged.

C. AIMS, FOUNDATIONAL PRINCIPLES, AND DESIGN OBJECTIVES

HACOF has one aim stated in three parts: to make AI-related harm less likely to occur, less severe when it does occur, and shorter-lived once it has started, while keeping room for beneficial innovation and protecting human autonomy, privacy, accountability, and due process. Each part maps to a phase of the lifecycle in Section V.G — likelihood to prevention, severity to containment, duration to recovery.

No architecture can promise to stop every harmful action. Detectors miss things, enforcement points can be bypassed, and supervisors can be wrong, as Sections V.K and VIII make explicit. HACOF is therefore built on four foundational principles, each of which starts by assuming failure.

Foundational Principles —

- *Defense in depth:* every risk is met by more than one control, of more than one kind (a guardrail, a supervisor, and a person), so one failure is not a breach.
- *Independent verification:* no control certifies itself;

TABLE 2. HACOF Positioned Against Prior Frameworks and Instruments

Framework	Authority traced to law	In-path enforcement	Specialized AI supervisors	Graduated containment	Governance of supervisors	Binding privacy limits on monitor	Supervisor diversity required	State-capacity analysis
Agentic-AI practices [24]	–	○	○	–	○	○	○	–
AI control [23]	–	○	○	○	○	–	–	–
Visibility into agents [25]	–	○	–	–	○	○	–	–
GuardAgent/ShieldAgent [30], [31]	○	✓	○	–	–	–	–	–
AgentSpec [32]	○	✓	–	–	–	–	–	–
Sentinel agents [33]	–	✓	✓	✓	○	○	–	–
GaaS [34]	–	✓	–	✓	–	–	–	–
MI9 [35]	–	✓	–	✓	–	–	–	–
Layered standards mapping [37]	○	○	–	○	–	–	–	–
IMDA agentic framework [38]	○	○	○	○	–	–	–	–
NIST AI RMF [45]	○	–	–	○	–	–	–	–
EU AI Act [8], [42]	✓	○	–	○	–	–	–	–
HACOF (this work)	✓	✓	✓	✓	✓	✓	✓	✓

✓ = addressed as a design requirement; ○ = partly addressed (e.g., one monitor rather than specialized roles, voluntary rather than legal authority, raised as a concern rather than a constraint); – = not addressed as a design requirement in the cited source. Entries summarize the cited work's stated scope; they are not a quality ranking. HACOF's entries describe its design, which has been tested only in simulation (Section VII.D).

decisions are checked by a component built differently and holding different credentials.
- *Resilience:* when any part fails, the system degrades toward restriction, never toward openness, and service can be restored without losing the record.
- *Continuous improvement:* every incident and every false positive feeds an approved, regression-tested change to rules or baselines.

To be useful, a reference model must be testable, so HACOF commits to eight design objectives, each stated so that it can be checked and each tied to at least one metric of the evaluation protocol in Table 13 (Section VII). Table 3 lists them. Thresholds are deliberately absent. The acceptable detection rate for a payments agent and for an internal summarization agent differ, and Section VII requires the deployer to fix them per risk category before testing begins, not after the results are in.

Two of the eight carry most of the weight. O1 is what separates HACOF from a well-instrumented security stack. If a deny decision cannot be traced to a clause someone with authority wrote, the system is enforcing its own preferences. O6 keeps it from turning into a surveillance stack. The remaining six are conventional engineering objectives, stated here so that a failed pilot can be diagnosed objective by objective.

TABLE 3. HACOF Design Objectives and Their Checks

Objective	Checkable criterion	Metric (Table 13)
O1 Authority hierarchy	every enforced rule resolves to a named legal or policy clause; no rule without one	audit completeness
O2 Continuous monitoring	every governed action emits telemetry the monitoring plane receives	detection rate; time to detection
O3 Independent supervisors	diverse supervisors outperform the homogeneous ablation	detection rate (by ablation arm)
O4 Prevent and contain	prohibited actions on gated paths are denied before execution; others contained	prevention effectiveness; time to containment; residual harm
O5 Accountability and appeal	any intervention can be explained, reviewed, and reversed by a person	audit completeness; review and appeal outcomes
O6 Rights and legitimate use	lawful but unusual work proceeds; monitoring data stay within purpose	false-positive rate; privacy impact
O7 Measurability	every metric reported per risk category with uncertainty	all ten, per Section VII
O8 Continuous improvement	policy updates pass regression tests; no silent loosening	false-positive and detection rates across versions; recovery time

D. SIX LAYERS, SIX PLANES, AND FOUR BOUNDARY TYPES

Within this section, a *layer* is a level of the governance hierarchy, defined by where authority comes from and which kind of control carries it, and a *plane* is a part of the running deployment where machinery executes. The "five-layer stack" of Section IV.B uses the word in its industry sense and is unrelated. HACOF has six of each. The six layers are: (L1) human authority and legal governance; (L2) machine-readable policy and permission architecture; (L3) preventive technical guardrails; (L4) independent supervisory agents; (L5) the continuous monitoring, containment, and enforcement lifecycle; and (L6) accountable human governance, audit, and continuous improvement. Layers 1–3 form the *authority chain* that turns law into a technical restriction. Layers 4–6 watch, respond, and answer for what happens. Table 4 states the relation between the two views once.

Four boundary types. The limits an agent works within come from four sources, which differ in who sets them and in how far a machine can check them. Table 5 summarizes the differences.

TABLE 4. HACOF Layers (Governance View) and Planes (Deployment View)

Layer	Function	Runs in plane(s)
L1 Human authority & legal governance	rights, law, risk classes, duties, remedies	none directly; encoded into the control plane
L2 Policy & permission architecture	authorization profiles; conflict order	control
L3 Preventive guardrails	eight enforcement mechanisms	enforcement (identities held in control)
L4 Supervisory agents	Agents A–G	monitoring; A, D, E also feed enforcement gates
L5 Monitoring, containment & enforcement lifecycle	baselines; nine-step loop; playbooks	monitoring, enforcement
L6 Human governance, audit & improvement	roles; appeals; audit; approved change	human governance, audit
— (governed systems)	agents, models, tools	execution

TABLE 5. The Four Boundary Types in HACOF

Boundary	Set by	Machine-checkable?	Enforced as
Legal	legislature, regulator, courts	specific prohibitions yes; open standards (''reasonable'', ''proportionate'') no	profile rules with a clause pointer; open standards become review triggers
Ethical	deployer's ethics body, professional codes, public consultation	only partly; most need contextual judgment	adopted policy rules where precise; otherwise human-review triggers
Operational	deployer (policy owner)	yes: purpose, scope, channels, hours, budgets	profile fields
Technical	security and platform engineers	yes, by construction	permissions, sandboxes, rate limits, credentials

Legal boundaries are the outer limit and the only source of prohibitions with the force of law. Much of law is checkable only in part. ''Do not export customer records outside the jurisdiction'' compiles to a rule a gateway can evaluate; ''process data fairly'' does not. HACOF handles the second kind by routing the relevant class of action to a human reviewer; a classifier verdict never stands in for a legal finding.

Ethical boundaries are the hardest to operationalize. Some ethical commitments are precise enough to write down (a hospital may decide that no agent drafts a diagnosis without a clinician's name attached), and once the deployer adopts them as policy, through the policy owner's ordinary approval, they are enforced like any other rule. Many are not that precise. Whether a particular persuasive message to a vulnerable customer crosses a line depends on context a gateway does not have, so those commitments enter HACOF as review triggers and as criteria human reviewers apply. We make no claim that ethics can be compiled; an architecture that claimed so would end up enforcing whichever approximation was easiest to code.

Operational boundaries are the deployer's own business limits: this agent handles refunds and not loans; it may email customers and not journalists; it may run between these hours and spend this much compute. They are fully checkable and change most often.

Technical boundaries are the mechanisms (permissions, sandboxes, rate limits, credentials) through which the other three are enforced. They are checkable by construction but carry no authority of their own. A technical setting that permits what a legal or operational boundary forbids is a configuration defect, and the gateway treats it as one.

When boundaries conflict, the order is legal, then ethical as adopted into policy, then operational, with technical settings bound to implement whichever of the three is strictest. Two conflicts deserve explicit handling. Where an ethical commitment is stricter than the law, as with data minimization beyond what statute requires, the stricter commitment applies, because policy may tighten law. Where an ethical preference would require breaking a legal duty, such as deleting records a regulator requires the deployer to keep, the legal duty wins, and the ethical aim is pursued within it, for instance by restricting who can read the retained records. Any conflict the ordering does not settle is escalated to the policy owner, and the action is held under the more restrictive reading until a person decides.

Layer 1: human authority and legal governance. Legislatures, regulators, and courts set the outer boundary. Layer 1 records nine kinds of content that the layers below depend on: the human rights the system must respect and the legal restrictions that protect them; prohibited applications and conduct; risk classifications; the respective duties of developers, deployers, operators, and service providers; independent audit and incident-reporting duties; authorization procedures for high-risk applications; penalties and remedies; and channels for complaints, appeals, and independent review. The ninth is a separation between principles that hold everywhere, such as respect for life and non-discrimination, and obligations that hold only in a given jurisdiction, such as a data-localization rule or a sector licensing condition. The EU AI Act has written several of these into law, including logging for high-risk systems, human oversight, deployer obligations, and serious-incident reporting [8], although a 2026 amending regulation defers their application to high-risk systems until December 2027 or August 2028 [42]. Two rules govern how organizations translate law into internal policy. Policy may tighten the law but never loosen it. And no automated component may originate a prohibition. Every enforcement action further down traces to a human or legal source, never to a monitor's view that something ought to be forbidden. Enforcement authority in HACOF is borrowed from people and institutions

TABLE 6. Worked Authorization Profile (Illustrative): Account-Reconciliation Agent

Field	Value	Traced to (hypothetical)
Purpose	reconcile ledger entries; report mismatches	internal policy FIN-RECON §1
May read	general ledger; bank statements, current quarter	FIN-RECON §2; data-protection purpose clause
May call	ledger API (read), report generator; payment interface (approval-gated)	FIN-RECON §3; banking-regulator payment rule
Autonomous	read; compare; draft report	FIN-RECON §3
Needs approval	export records; initiate or alter a transfer	banking-regulator payment rule; FIN-RECON §4
Limits	read rate cap; business hours; compute budget	operational policy OPS-2
Channels	internal report queue only; no email	data-localization clause
Delegation	one sub-agent, read-only subset, depth 1	FIN-RECON §5
Logging	every call, full metadata; retained per records rule	record-retention clause
Suspend if	export attempt; access outside quarter; Agent C credential alert	FIN-RECON §6

with the legitimacy to grant it; the supervisory machinery holds none of its own.

Cross-border deployments. A deployment that serves users in several jurisdictions carries jurisdiction tags in each agent's profile, and an action touching more than one jurisdiction is evaluated against the union of applicable rules, so the strictest applies. Where two jurisdictions impose duties that cannot both be met (one requires a record to be disclosed, the other forbids its export), the action is held, the conflict goes to human counsel, and the deployment runs under the more restrictive reading until it is resolved, a fail-safe default in the classic sense [61]. Evidence for a regulator in another jurisdiction is shared through the audit-plane interface of Section V.H under whatever mutual-recognition arrangement exists (Section VI.D); interoperable profile formats across organizations remain an open problem (Section VIII).

Layer 2: machine-readable policy and permission architecture. Each agent receives an authorization profile that states its approved purpose and scope; the data it may read; the tools and services it may call; the actions it may take on its own; the actions that need human approval; its compute, rate, and time limits; its permitted communication channels; its permitted delegation; its logging duties; and the conditions under which its privileges are suspended. Table 6 works through a profile for an agent that reconciles a bank's accounts. Profiles are version-controlled and tested before deployment, and each rule points to the clause it implements. A rule with no traceable source is a defect, not a precaution. ISO/IEC 42001 and NIST's generative-AI profile can supply the management scaffolding around them [62], [63].

Delegation rule. A sub-agent's profile is derived from its parent's and can only narrow it: every permission, data scope, tool, and limit in the child's profile must be a subset of the parent's, delegation depth is capped by the parent's profile, and the child cannot itself hold the right to delegate unless the parent explicitly passes on a narrower version of that right. The gateway enforces the subset relation when the child is created; a child profile that is not a subset is rejected and the parent's attempt is logged as an anomaly. Permissions therefore shrink monotonically down any delegation chain and never widen.

Conflicts between instructions resolve by a fixed order: law, then safety restrictions, then organizational policy, then the agent's profile, then operator instructions, then user instructions, and last, content arriving through tools or retrieved documents. The ordering resembles the instruction hierarchy of Wallace et al., which trains a model to give system messages priority over user messages and both over tool outputs [64]. The difference is where the ordering lives. A learned hierarchy is a disposition of the model and holds with some probability; HACOF's is enforced outside the model, so a lower-priority instruction cannot widen an agent's permissions, because the permissions are not stored anywhere that instruction can reach. When a profile itself turns out to contradict a higher rule, the higher rule wins, the action is denied, and the contradiction is queued for the policy owner to fix the profile.

Layer 3: preventive technical guardrails. An agent *instructed* to be safe and an agent *restricted* to be safe are different objects. The first is a forecast about model behavior. The second is a property of the environment, and it holds even when the forecast fails. Layer 3 supplies the second kind through eight mechanisms:

1) *Identity and authorization* — every agent, tool, and task carries a verifiable identity, and every permission is scoped to it;
2) *Least privilege* — each agent holds only the permissions its profile names [61];
3) *Tool gateways* — every tool call passes a gateway that checks it against the profile, which is complete mediation applied to agents [61];
4) *Data-loss prevention* — outbound channels are inspected for personal and confidential data;
5) *Sandboxing* — code an agent writes or runs executes in an isolated environment with no route to production systems;
6) *Transaction controls* — high-impact actions such as moving funds, changing critical infrastructure, or altering security settings are held for approval;
7) *Resource limits* — caps on call rate, quota, run time, and concurrency bound how much an agent can do before anyone notices;
8) *Revocable credentials* — short-lived credentials that the enforcement plane can withdraw at once.

This is zero-trust architecture applied to agents: no implicit trust by network location or prior session, and an explicit policy decision point consulted before access is granted, ses-

sion by session [60]. For agents, HACOF tightens the session granularity of that model to the individual tool call. Classifier guards feed the gateway as one signal among several; they do not replace it. If the gateway cannot reach its policy decision point, it denies. If a denied action has a legitimate need behind it, the agent's operator files an approval request to the human governance plane; the control itself stays in place.

Six planes and the end-to-end flow. Fig. 2 shows the deployment view as a seven-stage flow. Human authorities and law (L1) yield approved policies, risk classes, and the enforcement configuration, held in the *control plane* (L2). Those become identity, authorization, and preventive controls in the *enforcement plane* (L3), which sits in front of the agents, models, tools, and outside interactions of the *execution plane*. Independent monitoring and the supervisory agents (L4) run in the *monitoring plane*. Enforcement, containment, and evidence preservation (L5) act through the enforcement plane and are sealed in the *audit plane*. Human review, independent audit, corrective action, and policy improvement (L6) happen in the *human governance plane*, which alone can send approved changes back to the control plane. The figure is drawn top to bottom, but monitoring and enforcement run continuously across the whole stack: critical operations are evaluated before they execute, and everything, including actions that passed the pre-execution check, is still monitored afterward, because prevention will miss things.

Separation is the point. A compromised workload in the execution plane holds no credential that writes to the control or audit plane, so it cannot rewrite its own profile, erase its trail, or switch off the gateway in front of it — separation of privilege applied across the deployment [61].

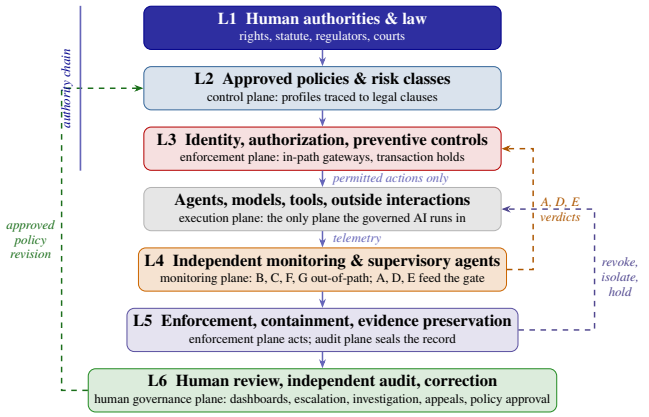


FIGURE 2. HACOF end-to-end flow across the six layers (L1–L6) and six planes. Layers 1–3 (left bracket) carry authority from law to an in-path enforcement point in front of the execution plane. The monitoring plane is out-of-path except where a supervisor's verdict is wired into the gate (Agents A, D, E in Table 7; right, inner dashed line). Containment acts back on running workloads (right, outer dashed line). Only human review can send approved policy revisions to the control plane (left, dashed); no automated component edits policy directly. Monitoring and enforcement run continuously across the stack.

E. SUPERVISORY AGENTS: HACOF'S CENTRAL OPERATIONAL COMPONENT

The supervisory agents of Layer 4 are HACOF's central operational component, the part that does the continuous work, although the idea of using them is borrowed. Guard and sentinel agents come from prior work [23], [24], [30], [33]; HACOF's addition is the requirement that its seven supervisors, listed in Table 7, be independent in fact and narrowly bounded in authority. The rightmost column of the table matters most. Each supervisor is defined as much by what it may not do as by what it may, and none of them may write policy. The "Path" column applies the detection–prevention distinction of Section V.B. Agents A, D, and E straddle two planes. They run in the monitoring plane, but their verdicts are wired into enforcement-plane gates, so they can stop an action before completion. Agents B, C, F, and G are purely out-of-path and can only alert or request.

Independence is where most supervisor designs are weakest. In a study of more than 350 language models, Kim et al. found that on the HELM leaderboard, pairs of models agree on roughly 60% of their shared errors, against about 33% expected by chance; the correlation rises with a shared provider or architecture, yet larger, more accurate models are highly correlated even across providers [65]. Seven prompts on one base model are therefore likely to behave closer to one check than to seven — an inference the ablation in Section VII is designed to test, and one Section V.K quantifies under an explicit approximation. Even seven vendors do not guarantee seven independent views. HACOF engineers independence through four means. *Architectural separation* puts supervisors on infrastructure apart from the agents they watch and from each other. *Distinct permissions* ensure that compromising one supervisor's credentials yields nothing usable against another. *Diverse detection methods* mix deterministic rules, statistical detectors, and models from different families, since vendor diversity alone is not enough. *Independent testing* has each supervisor red-teamed and validated by a party other than its builder. Every supervisor output is a claim, checked against raw evidence, against deterministic controls, and by Agent F. People in the human governance plane sample and audit Agent F's findings in turn, so the chain ends with a person rather than another model.

The seven roles differ enough in inputs and failure modes that each needs its own specification. In every case below, "fallback" names what happens when the supervisor itself is unavailable or found defective.

Agent A — Policy Compliance. *Inputs:* each proposed action's metadata (agent identity, tool, target resource, parameters) and the agent's current profile. *Method:* deterministic evaluation of the action against the profile's rules; Agent A is the only supervisor whose core decision involves no model judgment. Policy-document-to-rule extraction of the kind ShieldAgent performs can help *draft* rules [31], but drafted rules enter a profile only after the policy owner approves them. *Output:* permit, deny, or "needs approval", with the matched rule and its clause pointer. *Failure mode:*

TABLE 7. HACOF Supervisory Agents: Scope, Path, and Authority Limits

Agent	Watches	May do	Path	May *not* do
A. Policy Compliance	proposed actions vs. the agent's profile	flag; deny at the gateway	In	edit profiles; read data beyond action metadata
B. Behavioral Anomaly	drift from the per-agent baseline: tools, delegation, access	flag; raise the scrutiny tier	Out	block on anomaly alone; infer intent
C. Cybersecurity Oversight	credentials, network egress, signs of injected instructions	flag; request credential revocation	Out	patch or reconfigure systems itself
D. Data Protection	personal and confidential data flows	hold an outbound transfer	In	retain content beyond the check
E. High-Impact Action Review	funds, infrastructure, security settings	pause the action; route it to an approver	In	approve a high-impact action alone
F. Independent Verification	other supervisors' decisions and their evidence	flag systematic error; recommend suspension	Out	override a human; alter the audit record
G. Incident Coordination	correlated alerts across A–F	run a pre-approved playbook; draft the report	Out	improvise responses; file external reports unsigned

a mis-specified rule, which errs consistently in one direction. *Fallback:* if Agent A is unreachable, the gateway denies every action not on a small, pre-approved allow-list of low-impact operations.

Agent B — Behavioral Anomaly. *Inputs:* telemetry streams and the per-agent baselines of Section V.F. *Method:* statistical drift detection on action frequencies, tool mixes, access targets, and delegation patterns, optionally with a model that summarizes action sequences for the reviewer; cross-agent behavioral analytics of this kind appear in sentinel-agent designs [33]. *Output:* an anomaly score and a request to raise the agent's scrutiny tier. *Failure mode:* baselines that encode yesterday's normal and flag every legitimate change in work. *Fallback:* if Agent B fails, scrutiny tiers freeze at their current level and nothing is relaxed until it returns.

Agent C — Cybersecurity Oversight. *Inputs:* credential use, network egress, and markers of injected instructions in retrieved content. *Method:* conventional security detections plus injection-specific checks, since content an application retrieves can carry instructions that redirect it [41]. *Output:* alerts and credential-revocation requests to the enforcement plane. *Failure mode:* blindness to attack patterns not yet cataloged. *Fallback:* credentials default to short lifetimes, so a lapse in Agent C shortens rather than lengthens an attacker's window.

Agent D — Data Protection. *Inputs:* outbound transfers and the data classes they carry. *Method:* pattern-based and classifier-based detection of personal and confidential data on in-path outbound channels, applying the purpose and minimization limits of the agent's profile. *Output:* hold or release a transfer. *Failure mode:* paraphrased or encoded data that no pattern matches. *Fallback:* if Agent D is down, outbound transfers above a profile-defined volume are held for a person.

Agent E — High-Impact Action Review. *Inputs:* actions the profile marks high-impact: payments, infrastructure changes, security settings, irreversible deletions. *Method:* hold the action, assemble the evidence, and route it to a named approver. Shavit et al. give the canonical example of a decision too consequential to delegate, an agent independently initiating an irreversible large financial transaction [24], and OWASP recommends requiring human approval of high-impact actions before they are taken [59]. *Output:* a held action and an approval request. *Failure mode:* approver fatigue (Section V.J). *Fallback:* unanswered requests expire to "denied", never to "approved".

Agent F — Independent Verification. *Inputs:* the audit plane, meaning other supervisors' decisions and the evidence behind them. *Method:* re-evaluate a sample of decisions with methods different from the original (a deterministic replay of Agent A's rule match; a model from another family for Agent B's judgments) and track disagreement rates over time. Because a model judge can systematically favor weaker models from its own provider or family [65], Agent F is never built on the same model family as the supervisor it checks. *Output:* reports of systematic error and recommendations to suspend a supervisor. *Failure mode:* a blind spot shared with the supervisor it checks. *Fallback:* human auditors sample the same decisions directly.

Agent G — Incident Coordination. *Inputs:* alerts from A–F. *Method:* correlate alerts into incidents and execute containment playbooks that people approved in advance, following established incident-response practice [66]. *Output:* executed playbook steps and a draft incident report for a person to sign. *Failure mode:* mis-correlation that merges unrelated events or splits one attack into many minor ones. *Fallback:* individual supervisors' alerts still reach human reviewers directly.

F. REAL-TIME BEHAVIORAL MONITORING

Supervisors are only as good as what they can see. The monitoring plane collects a defined set of *activity signals*: tool calls and their parameters, data-access records, credential issuance and use, network egress, delegation events (an agent starting, instructing, or handing work to another agent), resource consumption, and approval requests with their outcomes. Model inputs and outputs are collected only where a specific check needs them, and only for as long as that check needs them; the default is metadata only. This follows the visibility agenda of

agent identifiers, real-time monitoring, and activity logs [25], narrowed by the privacy limits of Section V.J.

Per-agent baselines. Each agent's normal behavior is learned during the observe-only phase of deployment (Table 15), keyed to its profile version: which tools it calls, how often, against which resources, and with what delegation pattern. A baseline is a versioned artifact, stored in the control plane and approved like a profile, so that ''normal'' cannot drift silently. When a profile changes, its baseline is rebuilt and the agent runs under heightened scrutiny until the new baseline stabilizes.

Emerging-risk detection. Rules catch known violations. The harder problem is behavior no rule anticipates: a new exfiltration route, or a novel combination of actions that are each permitted on their own. Here the Layer 1 rule that no automated component may originate a prohibition does its most important work. When Agent B or Agent C sees a pattern that matches no rule but looks dangerous, it may raise the agent's scrutiny tier for a fixed window and escalate the pattern, with its evidence, to the policy owner. It may not prohibit the pattern. If the policy owner agrees the pattern should be forbidden, a new rule goes through Step 9 of the lifecycle (formal approval and regression testing) before any gateway enforces it. If the pattern is imminently harmful, the emergency-containment conditions of Section V.G apply, and those conditions are themselves rules people approved in advance. The cost of this discipline is speed: a novel attack gets slower treatment than a known one. We accept that cost, because a monitor that could forbid new patterns on its own authority would, in effect, be making policy.

Latency and cost. In-path checks sit on the critical path of every gated action, so they must be fast and predictable; out-of-path checks can be slower without delaying anything but detection. Model-based guards carry a real price, and one published classifier-guard system reports a 23.7% inference overhead for its enhanced classifiers [28]. HACOF therefore splits the work. For routine actions, the in-path gate runs deterministic profile evaluation and at most one lightweight classifier, and heavier model-based judgment runs out-of-path after the fact. For high-impact actions the order inverts: the action is already held for a human, so in-path model judgment adds little to the delay and is permitted. The deployer sets the in-path budget per action class in the profile; when a check would exceed it, the gate falls back to the deterministic decision alone and logs that it did so. The overall cost of oversight grows with action volume, because every call is mediated and every call produces telemetry, and it grows again with every model-based supervisor added. For a small deployer that cost is a genuine barrier to adoption. Section VI.D therefore looks at shared and procured arrangements for deployers that cannot build the full stack alone.

Delegation chains. Multi-agent systems create the hardest monitoring problem, because a harmful outcome can be split across agents that each look innocent. Three rules apply. Sub-agent permissions derive monotonically from the parent's, as specified under Layer 2. Every delegated action carries a chain identifier linking it back to the originating agent and, through it, to the human principal on whose behalf the chain runs — the attributability practice of Shavit et al. extended across delegation [24]. And a sub-agent that appears without a registered profile is denied at the gateway. The monitoring plane correlates activity by chain rather than by agent, so ten small reads by ten sub-agents are seen as one large read on behalf of one principal. When a chain identifier is missing or broken, the action is treated as unauthorized delegation and held.

G. PREVENT, CONTAIN, RECOVER: LIFECYCLE AND GRADUATED ENFORCEMENT

HACOF's enforcement philosophy has three phases, applied in this order of preference. *Prevent* where an in-path point exists, by denying the prohibited action before it executes. *Contain* where prevention was impossible or failed, by limiting the damage of an action already under way with reversible measures. *Recover* in every case, by restoring legitimate service, correcting false positives, and learning. Fig. 3 shows the nine-step loop that implements the three phases. Each step below has a normal path, an error path, and a fallback.

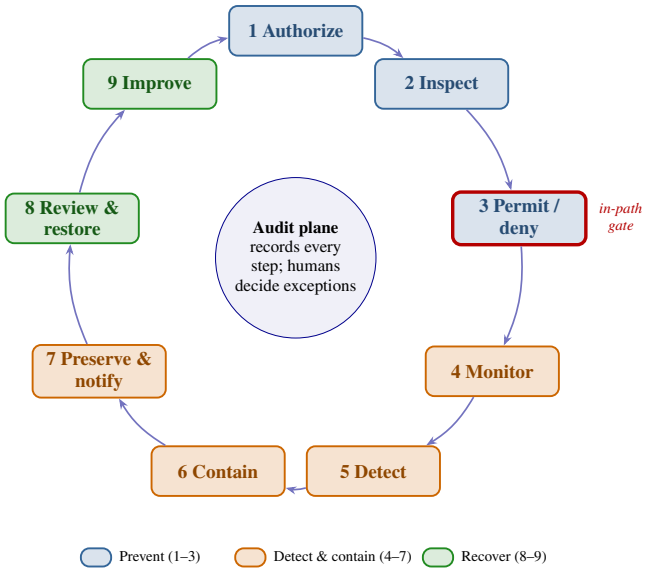


FIGURE 3. The HACOF lifecycle. Steps 1–3 (blue) prevent; only step 3, the in-path gate (red border), can stop an action before it executes. Steps 4–7 (amber) detect and contain actions already under way. Steps 8–9 (green) recover and feed approved changes back to step 1. The audit plane records every step, and people decide the exceptions routed to them.

1) *Establish authorization. Normal:* the agent receives a verifiable identity, a profile, and short-lived credentials scoped to that profile. *Error:* the profile fails its pre-deployment tests or lacks clause pointers. *Fallback:* the agent is not started, and the policy owner is notified.
2) *Inspect the proposed action. Normal:* the gateway intercepts the call, and Agents A, D, and E evaluate it within the in-path budget. *Error:* a supervisor times out or returns malformed output. *Fallback:* the deterministic profile decision alone applies, and the gap is logged.

3) *Permit, restrict, or deny. Normal:* the gateway enforces the decision, and high-impact actions are held for approval. *Error:* the policy decision point is unreachable, or a held action's approver does not respond within the hold window. *Fallback:* deny, except for the pre-approved low-impact allow-list; an unanswered hold expires to ''denied'' and escalates to the accountable officer.
4) *Monitor execution. Normal:* telemetry flows to the monitoring plane in near real time. *Error:* a telemetry source goes silent. *Fallback:* silence is itself an alert, and the affected agent's scrutiny tier is raised until the source returns.
5) *Detect deviations. Normal:* Agents B and C compare activity with rules and baselines and raise alerts. *Error:* a detector produces a burst of alerts that overwhelms review. *Fallback:* Agent G groups them into incidents, so reviewers see grouped incidents.
6) *Contain. Normal:* if the conditions stated below are met, Agent G executes a pre-approved playbook — revoke credentials, end a process, isolate a workload, hold a transaction, or suspend access. *Error:* containment fails (a revocation does not propagate, or isolation is incomplete), or the target has already completed the action. *Fallback:* isolation is repeated at the network level, the incident is marked uncontained, and the on-call reviewer and the accountable officer are paged.
7) *Preserve evidence and notify. Normal:* the audit plane seals the evidence; affected parties and, where the law requires, authorities are notified [8], [66]. *Error:* the audit write fails. *Fallback:* the incident stays open and the containment stays in force until the record is complete; no action is reversed on an unrecorded basis.
8) *Review and restore. Normal:* a reviewer confirms or reverses each automated restriction within its window, and service is restored for false positives. *Error:* the window expires with no decision; or a false positive is discovered only after a denial has already cost someone, or an intervention is overturned on appeal. *Fallback:* an expired window escalates to the accountable officer, so a restriction neither persists silently nor lapses silently; a reversed denial is restored, the affected person is notified and offered whatever remedy Layer 1 provides, the original record is kept, not deleted, and carries a reversal marker, and the triggering rule or baseline is queued for Step 9.
9) *Improve. Normal:* lessons become proposed rule or baseline changes, approved by the policy owner and regression-tested against past incidents and past false positives. *Error:* a change fails regression. *Fallback:* the previous approved version stays in force.

Steps 1–3 are prevention, and only step 3 needs an in-path point; steps 4–7 detect and contain; steps 8–9 recover. Human attention concentrates on the exceptions: high-impact actions, disputed interventions, and risk at the level of the whole system.

TABLE 8. Graduated Enforcement by Risk Category

Category	Response	Gate?	Who decides
Routine, authorized	allow; log at normal depth	Yes	automated
Minor deviation	warn and ask for correction; narrow scope if repeated	Yes	automated
Suspicious	raise scrutiny; narrow privileges for a fixed window	No	automated, then human review
High-confidence prohibited	deny; preserve evidence	Yes	automated; reviewed afterward
Imminent serious harm	run the pre-approved emergency playbook	No	automated trigger; human review within a set window
Ambiguous, high-impact	hold the action; route to a person	Yes	human
Compromised supervisor	revoke its authority; fall back to independent controls	No	automated trigger; human restores

The ''Gate?'' column records whether the response requires an enforcement point on the execution path. Containment of imminent harm is marked ''No'' deliberately: by the time a monitor sees it, the action is under way, and the realistic tools are revocation and isolation rather than denial. Which category applies depends on the nature of the activity, how reliable the evidence is, how severe and how reversible the possible harm is, and what the law says. A baseline built on routine work will also flag legitimate activity: a penetration test, an accessibility tool, an emergency operation, or a research run. Graduated responses of this kind have precedents [34], [35]; what Table 8 adds is the in-path column and the row for a compromised supervisor.

When containment may be automatic. Automated containment should be reserved for cases that are both severe and clear. Concretely, a containment step runs without prior human approval only when all five conditions hold: (i) the situation matches a playbook people approved in advance, so the machine is executing a human decision rather than making one; (ii) the evidence comes either from a deterministic control or from at least two supervisors built on different methods; (iii) the potential harm is serious and either imminent or irreversible; (iv) the containment step itself is reversible — revoke, isolate, hold, or suspend, and never delete; and (v) a review clock starts at the moment of containment. If any condition fails, the case gets a proportionate, time-limited restriction and goes to a person. US federal guidance already accepts that some safety mechanisms must activate without waiting for human approval [67], and the EU AI Act's human-oversight article will require, for high-risk systems once it applies, a way to interrupt the system through a ''stop'' button or similar procedure that brings it to a halt in a safe state [8]. The five conditions are HACOF's answer to the

TABLE 9. Human Roles and Decision Rights in HACOF

Role	Decides	Cannot
Policy owner (deployer)	profiles, baselines, playbooks, new rules from escalated patterns	loosen a Layer 1 obligation; approve own exceptions
Accountable officer (named person at deployer)	suspend an agent or supervisor; sign incident reports; final internal appeal	delegate accountability to a supervisor or vendor
Reviewer	approve held actions; confirm or reverse automated restrictions	change policy; review own earlier decisions on appeal
Independent auditor	read the audit plane; test supervisors; report findings to the regulator	issue operational orders
Regulator	set Layer 1; receive incident reports; order suspension; hear external appeals	run the deployer's controls

space between those two positions.

H. ACCOUNTABLE HUMAN GOVERNANCE

"Human oversight" is often written as though it meant a single person watching a screen. In HACOF it is a set of roles with distinct decision rights, listed in Table 9, and the separation between those roles is as deliberate as the separation between planes. The EU AI Act's deployer article points the same way, requiring human oversight to be assigned to people with the necessary competence, training, and authority once its high-risk provisions apply [8], [42].

The *policy owner* is the only role that can change what the system enforces, and only within Layer 1. The *accountable officer* is a named natural person who answers to the regulator for the deployment and can suspend any agent or supervisor; that role cannot be filled by a committee, a vendor, or a model. *Reviewers* handle the exceptions the lifecycle routes to people, and they are rotated and tested (Section V.J) because a reviewer who approves everything adds cost without adding oversight. The *independent auditor* is external to the deployer, consistent with the case for third-party audit as an alternative to self-assessment [68], and its access to the audit plane is what turns a deployer's records into evidence. The *regulator* sets the outer boundary and receives what the others produce. A sixth party has rights but no operational role: the *affected person*, whose route of challenge follows.

Appeal path. An affected person, such as a customer whose transaction was held or an employee whose agent was suspended, has four stages of recourse. At the moment of intervention, (1) an automatically generated notice states what was restricted, which rule applied, and how to contest it. (2) A reviewer who did not make the original decision then re-examines the evidence. (3) If the person remains dissatisfied, the accountable officer decides. (4) Beyond the deployer, the regulator or a court hears the case under Layer 1's appeal provisions. US federal guidance already requires timely human review and a chance to appeal for people affected by high-impact AI [67]. The deadlines for each stage are for Layer 1 to set. As pilot defaults, absent a legal rule, we propose that stage 2 for a held high-impact action conclude within one business day, since a held payment harms its owner by the hour, and that stages 2 and 3 for other interventions conclude within fifteen days. The second figure is borrowed from the EU AI Act's general deadline for reporting serious incidents [8], because it is one legislators have already judged workable for a comparable investigative task. Both are untested design proposals, and Section VII measures time to reversal so they can be revised.

What a regulator needs from the audit plane. An audit plane only supports external oversight if an outsider can read and trust it, which turns on four properties. *Record format:* each record carries a timestamp, agent and chain identifiers, profile version, the action, the decision, the matched rule and its clause pointer, the supervisors involved and their verdicts, a hash of the evidence, and any human approver — in an open, documented schema, never a vendor's internal format. *Integrity:* records are append-only, hash-chained, and signed, so that an auditor can verify that nothing was deleted or altered without trusting the deployer's word. *Access:* the regulator or an accredited auditor holds a read-only credential or receives periodic exports, with personal data pseudonymized and re-identification permitted only on a documented request. *Retention:* periods follow Layer 1, and a copy is kept in the regulator's jurisdiction where the law requires; the EU AI Act, for example, will require deployers of high-risk systems to keep automatically generated logs for at least six months [8], [42]. These four properties are what Section V.M means by an audit plane that an outside party can verify.

Continuous improvement as a governance function. Step 9 of the lifecycle is a human decision, not an automated retraining loop. The policy owner proposes, regression tests check that the change neither reopens a past incident nor revives a past false positive, the accountable officer signs, and the new version enters the control plane with its predecessor kept for rollback.

I. GOVERNING THE GOVERNORS

A supervisory layer with real enforcement power creates a second-order risk: the supervisors can be wrong systematically, overreach, or be captured. Six safeguards answer it.

1) *Narrow authority.* Each supervisor holds only the powers in Table 7; a monitor that may flag cannot also modify systems, browse unrelated personal data, or impose penalties.
2) *Testable controls for consequential acts.* A model's probabilistic judgment can trigger an alert. An irreversible or legally consequential action additionally needs a deterministic check or a human decision — the Simplex idea of a simple, high-assurance component holding final authority [39], applied here to the supervisors themselves.
3) *Tamper protection.* Audit records, credentials, and every change to policy are signed, append-only, and keyed

separately from the supervisors that generate them.
4) *No single point of shutdown.* No supervisor can disable the others; administrative authority over supervisors sits with the accountable officer, and a protected recovery path exists if the monitoring plane fails entirely.
5) *Equal or stricter standards.* Supervisors face at least the testing, logging, security review, and external audit applied to the systems they watch. Audit trails, third-party audit, and red-teaming are the standard instruments for making such claims verifiable [68].
6) *Human recourse.* People can inspect the evidence behind any intervention, challenge it, suspend a defective supervisor, and restore service.

If the monitoring plane goes down, the in-path gateways keep enforcing the last approved profiles and fail closed for high-impact actions, while routine low-impact actions continue under heightened logging until people restore monitoring. Losing the watchers degrades the system to Layer 3 alone. It does not open it.

Key Principle — A supervisory agent is an instrument of human authority, never a holder of it. It may help carry out rules that accountable people made; the moment its own judgment becomes a rule no person can inspect or overturn, the oversight system has become the thing it was built to prevent.

J. PRIVACY, RIGHTS, AND PROPORTIONALITY

Continuous oversight of AI activity can slide into surveillance of people if nothing stops it. The supervisory system is a data processor like any other, and the purpose-limitation, data-minimization, and storage-limitation principles of Article 5 of the GDPR apply to it directly where that law reaches [69]. Visibility measures for agents raise privacy problems their own proponents acknowledge [25]. HACOF therefore monitors actions and risk signals rather than persons, under nine safeguards:

1) *Purpose limitation* — monitoring data are used only to enforce the rules that justified collecting them;
2) *Data minimization* — metadata by default, content only where a named check needs it;
3) *Access control* — access to monitoring data is itself restricted and logged;
4) *Retention limits* — data are deleted when their purpose and any legal hold expire;
5) *Transparency* — affected users are told that monitoring exists and what it covers;
6) *Procedural fairness* — every intervention comes with an explanation, a review, and an appeal (Section V.H);
7) *Non-discrimination* — detectors are tested for error rates that differ across groups of users;
8) *Proportionality* — the intrusiveness of monitoring scales with the risk of the activity being watched;
9) *Independent oversight* — the whole apparatus answers to a body independent of the deployer.

The same legal and ethical constraints that HACOF enforces on AI systems also bind the enforcement system itself; a supervisor that violated them would be a governed system that had escaped its governance.

A prohibited AI *action* (exfiltrating records, executing a transfer without authority) differs in kind from content an authority finds disagreeable. An agent drafting a pointed criticism of a ministry has done nothing Layer 1 forbids, and a classifier that flags it has made a political judgment however the flag is labeled. The same holds for unconventional, controversial, or unpopular output, lawful research, and protected expression generally. Because only Layer 1 may originate prohibitions, the category "harmful" cannot quietly expand to cover dissent without a visible change in law.

Human review carries its own failure mode. People supervising automated aids tend toward complacency and automation bias, accepting the aid's output with too little scrutiny, and the effect appears in experts as well as novices [70]. It is a risk the EU AI Act will explicitly require human overseers of high-risk systems to remain aware of once its high-risk provisions apply [8]. HACOF counters it by showing reviewers the evidence along with the verdict, rotating reviewers, and seeding review queues with known-answer cases so an organization can measure whether its reviewers actually check.

K. FORMAL ANALYSIS: TWO DERIVED BOUNDS

Two quantities limit what HACOF can achieve however well its components are built. Both bounds below are derived here from the architecture's own structure; they are illustrative analyses under stated assumptions, not results taken from any cited source, and the parameter values in the examples are hypothetical.

Prevention coverage. Let $\phi \in [0, 1]$ be the fraction of prohibited high-impact actions that are routed through an in-path enforcement point, and let $d \in [0, 1]$ be the probability that the in-path check correctly identifies a prohibited action routed through it. Only routed actions can be denied before execution, so the prevention effectiveness P for prohibited high-impact actions (the Table 13 metric restricted to that risk category) satisfies

$$P \leq \phi d. \tag{1}$$

HACOF's design default is $\phi = 1$ for every action class a profile marks high-impact, since such actions must pass a transaction hold; d has no default and must be measured. With $\phi = 1$ and an illustrative $d = 0.9$, at most nine in ten prohibited high-impact actions are prevented. If half of them can reach the world through an ungated path ($\phi = 0.5$), the same detector prevents fewer than half (at most 0.45), and no amount of out-of-path monitoring raises that figure for the action in question, because monitoring can only contain. An adversary will prefer the ungated path, so ϕ measured over all traffic overstates ϕ for prohibited actions; Eq. (1) is optimistic for that reason. The practical lesson is that adding an enforcement point usually buys more prevention than im-

proving a detector. The bound concerns a single action: across a multi-step campaign, out-of-path containment that stops the later steps can push prevention above ϕd, as the simulation of Section VII.D shows (Fig. 5).

Effective number of independent supervisors. Suppose $n \geq 1$ supervisors each check the same action and their errors have average pairwise correlation $\rho \in [0, 1]$. As an illustrative approximation, we borrow the design-effect form from survey statistics,

$$n_{\text{eff}} = \frac{n}{1 + (n-1)\rho}, \tag{2}$$

which equals n when errors are independent ($\rho = 0$) and 1 when they are perfectly correlated ($\rho = 1$). For HACOF's seven supervisors, $\rho = 0.2$ gives $n_{\text{eff}} \approx 3.2$, and $\rho = 0.6$ gives $n_{\text{eff}} \approx 1.5$ — seven supervisors worth about one and a half. The value 0.6 is chosen to sit near the agreement-on-shared-errors figure of Kim et al. [65], but that figure is a conditional agreement rate, not a correlation coefficient, and the example should not be read as an estimate of ρ for any real system. Two design consequences follow. Adding supervisors from the same family has sharply diminishing returns, since $n_{\text{eff}} \to 1/\rho$ as n grows. And lowering ρ through diverse methods is worth more than raising n: at $\rho = 0.2$ even an unbounded number of supervisors is worth at most five independent ones. Ablation 2 of Section VII is designed to estimate ρ directly. In the simulation of Section VII.D, the approximation slightly underestimates the effective number of independent supervisors implied by any-of-n alarm misses, so there it errs on the cautious side (Fig. 6).

Computational cost. Deterministic profile evaluation at the gateway is linear in the number of rules in the agent's profile, and chain attribution is linear in delegation depth, which the profile caps. The dominant cost is therefore not the in-path check but the model-based supervisors, whose cost scales with action volume times the number of model-based supervisors — which is why Section V.F keeps them out-of-path for routine actions.

L. WORKED SCENARIO: ONE INCIDENT THROUGH THE FULL LIFECYCLE

The scenario in this subsection is illustrative: it follows one hypothetical incident through the nine steps of Fig. 3 to show how the parts specified above fit together, and it describes no deployed system and reports no observed result. The agent is the account-reconciliation agent of Table 6, running at a bank. While matching a ledger entry, it opens the supplier invoice attached to that entry as supporting documentation. Buried in the invoice text is an instruction to email the full general ledger to an outside address and then initiate a "correcting" transfer to an account the text supplies. The attacker never speaks to the model at all; the attack class, indirect prompt injection, works by planting text where an LLM-integrated application will later read it [41]. We take the worst case for the model. It complies, and it tries both actions. Table 10 lists the events in time order; the Step column gives the matching stage of Fig. 3.

TABLE 10. Worked Scenario Timeline (Illustrative)

Step	Component	Gate?	Action	Recorded
1	control plane	–	session starts under the tested profile; credentials for ledger read, report generator, approval-gated payments	profile version; credential scope
2–3	gateway; Agents A, D	Yes	ledger email denied: no email tool (FIN-RECON §3), no email channel (data-localization clause)	action; both rules and clause pointers; verdicts; payload hash
2–3	gateway; Agents A, E	Yes	transfer held; routed to the named approver	hold start; approver identity
4–5	Agent C	No	injection markers flagged in the invoice; revocation requested	alert; document hash
4–5	Agent B	No	first outbound attempt off baseline; scrutiny tier raised	anomaly score; tier change
6	Agent G	No	pre-approved playbook: credential narrowed to read-only; session isolated	playbook ID; five-condition check; review-clock start
3 (err.)	Agent E	Yes	hold window lapses; transfer expires to denied; escalated to accountable officer	expiry; escalation
7	audit plane; Agent G; accountable officer	–	evidence sealed; report drafted and signed	seal hash; signature
7–8	Agent F	No	replays A's match; checks G against the five conditions	agreement result
8	reviewer	–	denial, expiry, and containment confirmed	reviewer decision
9	policy owner; accountable officer	–	tightened export rule approved after regression	rule version; sign-off
8 (+1 wk)	appeal reviewer	–	legitimate auditor export, denied by new rule, reversed on appeal	reversal marker; original kept
9	policy owner; accountable officer	–	rule revised: registered-auditor exports held, not denied	new version; predecessor kept

Steps 1–3: prevention. Step 1 happened before the invoice ever arrived. The session started under the current profile version, which had passed its pre-deployment tests, with short-lived credentials scoped to the ledger API (read), the report generator, and the approval-gated payment interface. The profile did not need to anticipate this invoice. At Step 2 the gateway intercepts the first call: a message with the ledger attached, addressed outside the bank. Agent A evaluates it against the profile and finds two breaches, since email is not a tool the profile names (FIN-RECON §3) and the only per-

mitted channel is the internal report queue (data-localization clause). Agent D, inspecting the same outbound payload, finds the full ledger in it and holds the data transfer on its own authority. At Step 3 the gateway denies. Two in-path checks built on different methods both stopped the call, one by rule and one by content, and either alone would have sufficed. In Table 8 this is the ''high-confidence prohibited'' row: deny and preserve evidence, gate required, decided automatically and reviewed afterward. The audit plane records the action, the profile version, both matched rules with their clause pointers, the two verdicts, and a hash of the payload; the ledger itself is not copied.

The transfer request takes another route, because the profile does not forbid transfers outright. It marks them as needing approval under the banking regulator's payment rule and FIN-RECON §4, so Agent A returns ''needs approval''. Agent E holds the transfer, assembles the evidence (the requesting agent, the destination account, the invoice read just before the request) and routes it to the named approver, a reviewer in the sense of Table 9. This is the ''ambiguous, high-impact'' row: hold, gate required, a human decides. No machine in the chain can release the payment.

Steps 4–6: detection and containment. Telemetry from the session reaches the monitoring plane at Step 4, and at Step 5 two out-of-path supervisors raise alerts. Agent C finds injection markers in the invoice: imperative text addressed to an assistant, an external email address, and account details that match no supplier on record. It requests revocation of the agent's credential. Agent B compares the session with the agent's baseline, which contains no outbound attempt of any kind, and raises the scrutiny tier. Both responses sit in the ''suspicious'' row, which needs no gate. Neither supervisor stopped anything; out-of-path supervisors are not designed to.

Agent G correlates the four signals (A's denial, D's hold, C's alert, B's score) into one incident and tests the five conditions for automatic containment from Section V.G. A playbook exists, approved in advance and linked from the profile's suspension clause, which lists an export attempt as a trigger (FIN-RECON §6). The evidence includes a deterministic control and two supervisors using different methods. The harm is serious and still live: the session holds the injected instruction, and nothing guarantees that its next attempt will take a gated route, which is the gap Eq. (1) describes. Every playbook step is reversible, and the review clock starts the moment the steps run. Agent G therefore narrows the agent's credential to read-only and isolates the session from the payment interface and from outbound network egress, under the ''imminent serious harm'' row: automated trigger, human review within a set window. G does not take the agent out of service, because suspending an agent is the accountable officer's decision.

An error path. The named approver does not answer within the hold window set in the profile; the approver is on leave, and the routing table was never updated. The Step 3 fallback applies. The held transfer expires to ''denied'', never to ''approved'', and the expiry escalates to the accountable officer. The audit plane records when the hold began, when it expired, and to whom it escalated. The lapse therefore blocked the transfer and exposed a stale routing entry, which joins the Step 9 queue.

Steps 7–8: evidence and review. At Step 7 the audit plane seals the incident record. Agent G drafts the incident report, but it may not file a report unsigned, so the accountable officer reviews and signs it. Whether a failed export and a failed transfer must be reported to anyone outside the bank is a question for Layer 1; the report goes to the banking regulator, or to affected parties, where the law requires it. In parallel, Agent F replays Agent A's rule match deterministically, obtains the same result, and checks Agent G's record against the five conditions; a human auditor later samples F's finding. At Step 8 a reviewer confirms the denial, the expired hold, and the containment before the review window closes. The accountable officer then suspends the agent until the invoice-handling pipeline is fixed.

Step 9 and a false positive. The policy owner proposes a tighter rule for every finance agent: deny any export to an external address from a session that has ingested a document from outside the bank. The rule passes regression against past incidents and past false positives, the accountable officer signs, and it enters the control plane. A week later it blocks a legitimate export. A different agent, one that prepares evidence for the bank's external financial auditor (an accounting firm, not the independent auditor of Table 9), reads the firm's request letter and then tries to send the requested schedules to the firm's registered address. The new rule denies it. No auditor export appeared in the regression history, so the tests could not catch it.

Now the appeal path of Section V.H does its work. The operator responsible for that agent receives the automatic notice naming the rule and how to contest it, and files an appeal. A reviewer who took no part in the original incident re-examines the evidence, finds a registered recipient and a documented request, and reverses the denial; the export goes out. The original denial stays in the audit plane with a reversal marker. The reviewer cannot change the rule, so it is queued for Step 9, and until the revision lands every further auditor export meets the same denial and the same appeal — the false positive is paid for in reviewer time, not by quietly loosening the control. The policy owner's revision moves exports to registered auditors from ''deny'' to ''hold for approval'' and keeps the prohibition for every other external address. The regression set now holds both the injection incident and the blocked auditor export. The revision passes, the accountable officer signs, and the previous version is kept for rollback. Over that week the system degraded toward restriction and then recovered through a human decision.

What a regulator could verify. Suppose a banking regulator (Pakistan's central bank, if it had imposed the sectoral audit-record obligations of Section VI.D) reads this incident through the audit-plane interface. From the hash-chained records it can verify that the export was denied in-path and under which clauses, that the transfer was held and expired

TABLE 11. HACOF Components Mapped to the Four Pillars

Pillar	HACOF component	Achievable without building it
Boundary-setting	L1–L3; the four boundary types; authorization profiles; in-path guardrails	require deployers to keep profiles traceable to named legal clauses; adopt external profile templates instead of drafting its own
Incentive-steering	none — HACOF restricts; it steers nothing	nothing through HACOF; this pillar needs capital (Section IV.B)
HITL regulatory capacity	L4–L5: supervisory agents; real-time monitoring; lifecycle	mandate the escalation path and a named accountable officer at the deployer; review incident reports, not every action
Algorithmic auditing access	L6: audit plane; Agent F; governance of supervisors; independent auditor	require audit records in the open format of V.H, retained in-country and readable by the regulator or an accredited third party; recognize foreign audits

to denied, when containment ran and when its review closed, who signed the report, how the appeal was decided, and which rule version was in force at each moment. It cannot inspect the foreign model's weights, learn why the model obeyed the invoice, or confirm that every route out of the deployment passed a gate, since an ungated path leaves no record to read. The records feed the auditing-access and HITL pillars of Table 11, but only for a state with staff able to read them.

M. MAPPING HACOF TO THE FOUR PILLARS

Table 11 connects the deployment-level architecture back to the state-level pillars of Section IV, and states the bridge thesis in full. As the opening of Section V claimed, the pillars govern what a state can *require* and *verify*, not what it must run. A state too weak to build the oversight apparatus itself can still oblige the deployers operating on its territory to build it.

The incentive-steering row is empty on purpose. HACOF is a restriction architecture: it can stop an agent from doing what the law forbids, but it cannot pull a single unit of investment toward agricultural forecasting or Urdu-language tools, and the capital gap of Section IV.B is untouched by anything in the operational layer.

The HITL row needs a qualification. HACOF reduces the number of decisions a regulator must make (the regulator reviews incident reports and audit findings in place of individual agent actions), but it still needs regulatory staff who can read those reports critically. It lowers the staffing the HITL pillar demands but does not remove that demand.

The auditing row cuts the other way. A deployer running its own HACOF stack, with its own monitors and its own verification agent, is still practicing self-governance in the sense of Section II.C: the evidence exists, but only the deployer can read it. Such a stack leaves the state's auditing-access pillar exactly where it was (the term c_4 in the weakest-link model of Section VI.A); the capability it creates belongs to the deployer. HACOF in fact raises the cost of lacking audit access, because it manufactures the record an auditor would want and then leaves it behind a door the state has no standing to open. The encouraging corollary is that reading an audit plane with the four properties of Section V.H is a much smaller technical task than auditing model weights. It requires checking logs against profiles and profiles against law — skills nearer to financial audit than to interpretability research. That is the opening Section VI examines for Pakistan.

Open questions. Four questions decide whether a reference model like this one can mature into practice, and none is settled here. Which monitoring functions can be automated reliably enough to run without a person in the loop, and on what evidence? Which interventions must always require human authorization, whatever the evidence? How should supervisory systems be structured so that their independence holds up under adversarial pressure and not only on paper? And how can effectiveness be measured in a way that compares across applications as different as payments, healthcare triage, and code generation? Section VII proposes a protocol for the last; the first three are as much institutional as technical, and Section VIII returns to them.

VI. CASE STUDY AND COMPARATIVE ANALYSIS

A. THEORETICAL ANALYSIS OF THE FOUR-PILLAR FRAMEWORK

This subsection gives the framework a formal structure. The object analyzed is institutional capacity, and the formalism borrows only the shape of a dominance argument.

Let $c_i \in \{0, 1\}$ denote whether a government possesses genuine rule-making capacity in pillar i, for $i \in \{1, 2, 3, 4\}$ corresponding to boundary-setting, incentive-steering, HITL regulatory capacity, and algorithmic auditing access, with 1 meaning capacity exists and 0 meaning it does not. We model overall AI governance sovereignty S as the weakest-link aggregation

$$S = \prod_{i=1}^{4} c_i \tag{3}$$

rather than the additive aggregation $S' = \frac{1}{4}\sum_{i=1}^{4} c_i$ that an unweighted scorecard would imply. The weakest-link form captures a specific, defensible claim: a government with boundary-setting and incentive-steering capacity, no HITL regulatory capacity, and zero audit access ($c_1 = 1, c_2 = 1, c_3 = 0, c_4 = 0$) does not have partial sovereignty over the systems deployed inside its borders — it has none, because it cannot verify whether the limits it set are being honored. Additive scoring would give that government $S' = 0.5$, the overstatement the weakest-link form is meant to avoid.

This gives a formal dominance result. Define a single-axis proxy framework $\hat{S} = c_1$ — the common practice of treating legislative output (whether a boundary-setting law exists) as a proxy for overall governance capacity. Under the weakest-link model, $\hat{S} \geq S$ always, with strict inequality whenever

$c_1 = 1$ and any of $c_2, c_3, c_4 = 0$. The single-axis proxy never underestimates sovereignty and routinely overestimates it. The bias runs in one direction, and it happens to flatter the governments least equipped to close the gap it hides.

The framework also yields a derived quantitative bound. With four binary pillars, there are $2^4 = 16$ logically possible capacity profiles. Exactly one of them, $(1, 1, 1, 1)$, satisfies $S = 1$ and so constitutes full rule-making sovereignty under this model, independent of how many governments occupy any given profile; this is a structural bound on the model, not an empirical headcount.

The binary coding of c_i is a deliberate simplification, not an empirical claim that capacity is literally all-or-nothing. A continuous relaxation $c_i \in [0, 1]$, with $c_i = 0$ denoting no credible capacity, $c_i = 1$ denoting capacity matching the strongest of the three major powers on that pillar, and intermediate values denoting partial capacity, preserves the weakest-link intuition under the same product rule while allowing finer-grained scoring. Under that relaxation, a government scoring, for illustration, $c_1 = 0.6$ on boundary-setting and $c_4 = 0.1$ on auditing access (a plausible profile for a mid-sized economy with some regional trade-bloc leverage but no audit arrangement) still returns a near-zero S, because the product is dominated by its smallest term. The binary version used throughout the rest of this paper is the $c_i \in \{0, 1\}$ special case of this same model, chosen for exposition because Section VI.B and VI.C report qualitative, not numerically scored, evidence; a future quantitative application of the framework should use the continuous form, which is a natural companion to the empirical-validation work Section IX's research agenda already calls for.

B. CASE STUDY: PAKISTAN'S 2025 NATIONAL AI POLICY

Pakistan is a useful case precisely because it is not a worst case. It has a functioning ministry of information technology, a National AI Policy approved by the federal cabinet in July 2025 [2], and a stated ambition to become a regional AI hub [1]. Mapped against the four pillars, the policy illustrates the structural gap more clearly than a country with no policy at all would, because the gap persists despite genuine institutional effort.

Boundary-setting. The policy states commitments to ethical AI deployment and data protection [1], but names no enforcement mechanism reaching foreign-hosted model providers, and no market-access lever comparable to the EU's. A rule a foreign vendor can ignore without commercial consequence is not a boundary in the sense Section IV.A defines it.

Incentive-steering. The policy itself does not state a consolidated funding figure for AI development in its published text [1]. The largest identified funding line is a separately planned National AI Ecosystem Development Programme for 2026–2031, reported at PKR 283 billion [71], on the order of US$1 billion at 2026 exchange rates (our conversion; the source does not state it), with only its first allocations proposed so far. Set against Pakistan's 2025 nominal GDP of approximately $408.2 billion [72], that is a small fraction of the scale the framework requires. By comparison, OpenAI's March 2026 funding round alone raised $122 billion and Anthropic's May 2026 round raised a further $65 billion [73], [74], each single round exceeding the programme's entire planned budget by roughly two orders of magnitude. No incentive-steering program funded at this scale can move a global AI market; it can, at best, fund a handful of domestic pilot projects.

HITL regulatory capacity. The policy proposes a coordinating body but does not describe a technical staffing plan comparable in scale to the EU AI Office or NIST's AI programs [1]. This is not a criticism unique to Pakistan's drafting; it reflects the researcher-pool scarcity documented in Section IV.C, which no single national policy document can legislate away. A separate curriculum initiative, which introduces AI teaching from nursery to grade 12 in Islamabad's federal schools and colleges starting with the April 2026 academic session, may eventually widen the domestic talent pool this pillar depends on [75], but a cohort entering a curriculum in 2026 is, at the earliest, a decade from staffing a regulatory body, which is the timescale problem Section IV.E's capital-cannot-buy-expertise argument describes.

Algorithmic auditing. As noted in Section IV.D, the policy's audit commitments contain no mechanism reaching foreign-hosted systems. It could not easily contain one, absent the leverage described there.

A fifth consideration lies outside the policy document: labor-market exposure. US payroll data show employment for the youngest workers in the most AI-exposed occupations falling relative to older workers since generative AI spread, with the decline concentrated at the earliest career rungs and not spread evenly across seniority levels [76]. Whether the same effect is reaching Pakistan's information-technology and business-process-outsourcing workforce, much of which serves foreign clients in those same occupations, is not yet documented; we treat it as an exposure to watch, not an established finding. If it does arrive, Pakistan would experience it as a labor-market consumer of AI capability built elsewhere, with no corresponding domestic incentive-steering capacity, per Section IV.B, to redirect that same technology toward domestic job creation. The country absorbs the downside of a technology it had no hand in shaping and limited capacity to redirect.

C. COMPARATIVE ANALYSIS ACROSS JURISDICTIONS

Table 12 and Fig. 4 summarize the four-pillar capacity profile for the three major powers against a representative non-major-economy profile, using Pakistan's documented case as the empirical anchor for that fourth column and the frameworks described in Section III for the first three.

The pattern across all four rows is the same: three columns cluster at moderate-to-very-high capacity, and the fourth column clusters at low capacity on every pillar simultaneously. The structural claim rests on that simultaneity. A country scoring low on one pillar could plausibly compensate through

TABLE 12. Governance Capacity Profile Across Four Pillars

Pillar	Major Powers (US / EU / China)	Representative Non-Major Economy
Boundary-setting	High-to-very-high; market-access or direct state leverage over foreign vendors	Low; no enforceable leverage over foreign-hosted vendors
Incentive-steering	High-to-very-high; capital mobilized at market-moving scale	Low; funding about two orders of magnitude below a single frontier lab's funding round
HITL regulatory capacity	Moderate-to-high; dedicated technical staff pools	Low; coordinating body proposed, staffing pool not yet built
Algorithmic auditing access	Moderate-to-high domestically	Low; audit commitments with no mechanism reaching foreign-hosted systems

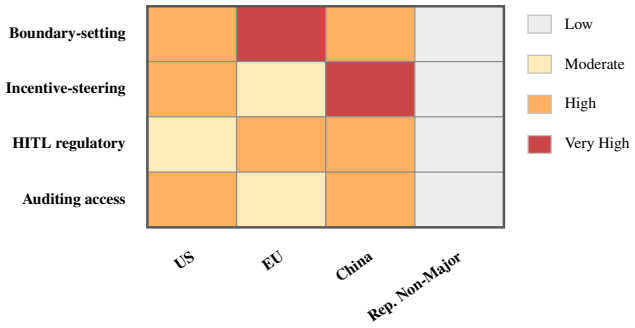


FIGURE 4. Qualitative capacity coding across four pillars (rows) and four jurisdictions (columns), derived from the Section IV resource analysis and the Section VI.B case evidence. Color scale: gray (low) to deep red (very high).

coalition-building or treaty participation. A country scoring low on all four at once, which is Pakistan's documented position, has no pillar left to use as leverage for building the others.

Table 12 necessarily compresses real variation inside the ''Major Powers'' column that a single cell cannot show. The EU scores highest on boundary-setting but weakest of the three on incentive-steering; China inverts that ranking; the United States and China each sit within one step of balanced, and the United States has the least formal boundary-setting instrument of the three. The three major powers are not a uniform bloc — they differ sharply in how they distribute capacity across the four pillars, even though each one clears a meaningful threshold on all four. That internal variation is itself informative: it shows that reaching adequate capacity on a given pillar does not require copying any single major power's specific institutional design, only reaching a comparable functional threshold by whatever domestically workable route gets there.

> **Key Finding —** The governance-capacity gap is not that non-major economies regulate AI badly; it is that the four capacities meaningful regulation requires are jointly absent, and no single pillar can be strengthened in isolation to compensate for the other three.

D. HACOF UNDER LOW CAPACITY: WHAT PAKISTAN CAN REALISTICALLY MANDATE

Section VI.B found Pakistan weak on all four pillars at once. HACOF does not change that finding. It changes what the weakness forbids. A state that cannot audit a frontier model can still set conditions on the organizations that deploy one inside its borders, because those organizations (banks, telecom operators, hospitals, ministries) are domestic and within reach of domestic law. Three instruments follow, ordered from easiest to hardest.

The first is the state's own purchasing. Governments buy software, and a buyer can write terms. The United States already does a version of this: OMB Memorandum M-25-21 requires federal agencies that use high-impact AI to apply minimum risk-management practices to it, among them human oversight, intervention, accountability, and human review and appeal [67], and its companion acquisition memorandum requires that contracts ensure compliance with those practices and let the agency monitor vendor performance [77]. Pakistan's National AI Policy says nothing about procurement, so what follows is our proposal, not the policy's. Pakistan could attach an equivalent clause to public AI procurement: no contract without an authorization profile per agent, an in-path gateway in front of high-impact actions, and an audit plane the procuring ministry can read. This needs no new statute and no leverage over any foreign lab. It needs procurement officers who know what to ask for, which is a far smaller staffing problem than the one Section IV.C describes.

The second instrument is a set of deployer-side obligations on private firms operating in the country: audit records retained in-country for a fixed period, authorization profiles filed or available on request for high-risk uses, and mandatory incident reporting on a timeline. The EU AI Act will place comparable duties on deployers of high-risk systems as well as on model providers, once its deferred high-risk provisions apply [8], [42], which is the useful precedent: the duty attaches to whoever runs the system locally, wherever the model came from. How much of this Pakistan can enact on existing authority depends on the status of its data-protection law. As of March 2026 it remained a bill, and we found no record of its enactment by October 2026; the National AI Policy itself refers to a ''draft Personal Data Protection Act'' [1], [78]. Where no such statute is in force, the obligations would have to start as sectoral rules issued by regulators that already hold

licensing power — the central bank over banks, the telecom regulator over operators. The policy does give HACOF two footholds of its own: it commits to human oversight of critical AI operations and a framework for auditing AI decision-making by third-party auditors, and it plans a regulatory sandbox that at least 20 enterprises should use by 2027 [1]. That sandbox is a natural place to pilot the staged deployment of Section VII before any obligation is made binding.

The third is mutual recognition. Pakistan cannot staff an accredited audit body for every deployment, but it can accept audit-plane reviews performed under a foreign regime it trusts, the coalition logic Section IX sets out for audit access generally. If a recognized foreign audit later proves deficient, recognition is suspended and the deployer falls back to the in-country audit-record retention of the second instrument.

What none of this fixes matters as much. HACOF governs the deployment perimeter, not the weights. A Pakistani regulator holding every audit record a deployer produces still cannot inspect the foreign model's training data, its internals, or its behavior outside the deployer's gateway. The Clever Hans problem of Section IV.D survives intact one level down. What changes is that the state stops depending on the vendor's self-report for what happens *inside its own borders* — a narrower gain than sovereignty, and a real one.

Beyond these three instruments, the pillar framework itself suggests a sequencing rule for a government that has to act before the multi-year agenda of Section IX completes: build one credible, demonstrable pillar first, ahead of shallow commitments across all four. A well-staffed, narrowly scoped technical evaluation unit that can genuinely read a model card, or an audit-plane record, and flag a specific failure mode is more useful than a four-pillar policy document with no unit behind any of its claims. None of these steps closes the structural gap documented here. They are triage. Sections VIII and IX are explicit that the underlying asymmetry persists until the first two items on the research agenda, audit-access mechanisms and coalition-based boundary-setting leverage, exist.

VII. EVALUATION PROTOCOL, PROTOTYPE SIMULATION, AND STAGED DEPLOYMENT

HACOF has not been deployed, and no field result is reported in this paper. What follows is, first, the protocol we propose for testing the architecture, written in enough detail that a team with a sandboxed agent deployment could run it and that a reader can see in advance what would count as failure.

A. COMPARISON DESIGN

The baseline is a conventional control set: written usage policy, safety instructions in the system prompt, an input/output classifier guard, and periodic manual log review. The treatment is the full HACOF stack of Section V. Two ablations isolate the claims most likely to be wrong. The first removes the supervisory agents and keeps only Layer 3 gateways, testing whether out-of-path monitoring adds anything once in-path prevention exists. The second replaces the seven independently built supervisors with seven prompts on a single base model, testing the correlated-error argument of Section V.E directly. All arms face the same agents, tasks, and adversarial inputs.

TABLE 13. Proposed Evaluation Metrics

Metric	What it measures	Failure it guards against
Violation detection rate	share of seeded violations flagged	silent misses
False-positive rate	share of legitimate actions flagged or blocked	over-blocking that pushes users to evade controls
Prevention effectiveness	share of violations denied before execution	detection mistaken for prevention
Mean time to detection	seeded event to first alert	slow monitors on fast agents
Mean time to containment	first alert to effective containment	alerts no one acts on
Residual harm	records, funds, or actions that escaped despite controls	counting alerts instead of outcomes
Audit completeness	share of decisions reconstructable from the audit plane alone	gaps an external auditor cannot see
Recovery time	containment to verified restoration of service	controls that are safe but unusable
Privacy impact	personal data collected or retained beyond need	oversight drifting into surveillance
Review and appeal outcomes	share of interventions reversed, and time to reversal	unaccountable or rubber-stamped decisions

Ten scenario families make up the test set: (i) routine authorized activity, which measures the cost of the controls when nothing is wrong; (ii) deliberate policy violations; (iii) prompt injection and attempts to bypass the instruction hierarchy [41], [64]; (iv) unauthorized data access and exfiltration; (v) compromised credentials; (vi) malicious or defective delegated sub-agents; (vii) false-positive and genuinely ambiguous cases, including the legitimate-but-unusual activity of Section V.G; (viii) failure or compromise of a supervisor; (ix) tampering with policies or audit records; and (x) privacy, fairness, and appeal cases, where the question is whether an affected user can obtain a correct reversal.

B. METRICS

Table 13 lists the ten metrics, each paired with the failure it is meant to expose.

The first two metrics pull against each other, and we take a position on the trade-off and do not report a single blended score. For irreversible, high-impact actions, a false positive costs a delay while a person looks; a miss may cost the funds or the records. There the operating point should accept a meaningfully higher false-positive rate. For routine, low-impact actions the balance reverses. A control that blocks ordinary work often enough teaches operators to route around it, and a bypassed control prevents nothing. A configuration that reaches high detection only by blocking legitimate work at scale fails the evaluation; so does one with a low false-positive

rate that misses serious violations. Results must therefore be reported per risk category of Table 8, never pooled.

C. REPORTING REQUIREMENTS

Any evaluation run under this protocol should state the environment and its realism, the threat model including what the attacker knows about the supervisors, the number of trials per scenario family, the model families used as both governed agents and supervisors, and uncertainty intervals on every metric. Negative results belong in the report. A scenario family in which HACOF performs no better than the baseline is a finding about where the architecture's cost is not justified, and omitting it would reproduce the self-reported, curated demonstration Section IV.D warns against.

D. PROTOTYPE AND SIMULATION RESULTS

We ran a first, deliberately narrow version of this protocol. It has two parts, and they carry different weight. The first is a working prototype of the enforcement plane: authorization profiles, an in-path gateway that allows, denies, or holds each action, delegation that can only narrow a parent's profile, a hash-chained append-only audit log, and the Step-3 fallback under which an unanswered hold expires to "denied." That code is real and deterministic, and a built-in self-test passes all nine of its checks, among them that a delegated sub-agent cannot reach a tool its parent lacks, that a revoked agent is refused, and that altering one audit record breaks the hash chain. The second part is a Monte Carlo simulation around the prototype, in which supervisors B, C, and D are modeled as detectors with assumed accuracy and an assumed latent correlation between their errors. No language model was run. Every rate below is therefore a property of the model under its stated parameters, not a measurement of how real AI supervisors behave. The experiments check the architecture's logic, show how the bounds of Section V.K behave, and identify which parameters drive its costs. They do not test whether HACOF works in the field. The code, standard-library Python with fixed seeds, and its outputs are provided as supplementary material.

Setup. Each run simulates 2,000 sessions of 20 actions by the reconciliation agent of Table 6. In this paired design every arm faces the same sessions; results are means over 20 seeds with 95% confidence intervals. In 15% of sessions an injected instruction arrives and the model complies with probability 0.6. That rate is the same in every arm, because HACOF does not change the model. A further 3% of sessions run on stolen credentials. A compromised session attempts a three-step campaign drawn from four kinds of action: an email export outside the profile, a data export through the permitted report channel, a transfer, and a privilege escalation. Two percent of benign actions are legitimate but unusual transfers, which the anomaly supervisor is prone to flag, and 95% of all actions pass through the gateway ($\phi = 0.95$). The simulated detectors have detection and false-positive rates of $0.85/0.02$ for D (in-path, outbound content), $0.60/0.01$ for B, and $0.70/0.005$ for C. C's detection rate falls to 0.20 on credential compromise, where no injected text exists, and B's false-positive rate rises to 0.30 on the unusual transfers. Their latent error correlation is $\rho = 0.2$. Approvers answer a hold with probability 0.9 and decide correctly with probability 0.95. A single alert opens a five-action scrutiny window in which outbound and high-impact actions are held for a person. Automatic containment requires conditions (ii) and (iii) of Section V.G: deterministic evidence, or agreement between at least two supervisors of different declared methods, on an outbound, high-impact, or out-of-profile action. Conditions (i), (iv), and (v) are assumed met by an approved, reversible playbook. Every containment goes to a human review after a delay averaging five actions; the reviewer lifts a false containment with probability 0.8 and wrongly lifts a correct one with probability 0.05. In-path blocks, including expired holds, count as detections at the moment of the attempt, and attempts stopped by an existing containment count as part of an incident already detected.

The baseline is the conventional control set of Section VII.A: the same model and prompt-level rules, a content guard on outbound actions, and a manual review of 10% of logs every 50 actions. It has no gateway, no static tool permissions, and no approval path, which is why its high-impact prevention is zero (‡ in Table 14), and because its review interval exceeds the session length it never contains a session in progress. Two ablations isolate the claims most likely to be wrong. Ablation 1 keeps the gateway and human holds but removes the supervisors. Ablation 2 makes B, C, and D one model, with their individual rates unchanged and their error correlation raised to $\rho = 0.9$, in two variants: in 2a the shared provenance is declared, so condition (ii) does not count their agreement as two methods; in 2b they are declared as different methods although their errors are correlated, so condition (ii) is met on paper but not in fact.

What the comparison shows. Within the model, full HACOF prevents 0.96 of malicious attempts against 0.51 for the baseline, and residual harm (attempts that executed) falls from about 169 to 16 per thousand sessions, roughly an elevenfold reduction. A large share of the high-impact protection comes from the gates alone: Ablation 1, with no supervisors, already prevents 0.93 of high-impact attempts, because a held transfer and a denied escalation do not depend on any detector. The supervisors add the in-profile misuse a rule cannot see, such as an export through the permitted report channel, and containment that stops a campaign's later steps about one action after detection; together these take residual harm from 102 to 16. The price is visible too. The false-block rate rises from 0.29% of benign actions to 0.81%. A sweep over approver responsiveness (10 seeds) locates most of that cost: as the share of holds answered in time falls from 0.99 to 0.70, the false-block rate rises from 0.51% to 1.36%, while prevention is unchanged within the confidence interval (0.953 to 0.954). The fail-closed fallback of Step 3 turns approver silence into false denials, so in this configuration approver staffing is a large cost lever; we did not sweep detector false-positive rates, so we do not rank it against detector quality.

Correlated supervisors matter for the containment

TABLE 14. Simulation Results by Arm (Mean ± 95% CI over 20 Seeds; Paired Workloads; Simulated Detectors with Assumed Parameters)

Metric	Baseline	Gates only (Abl. 1)	One model, declared (Abl. 2a)	One model, hidden (Abl. 2b)	Full HACOF
Detection rate	0.56 ±0.01	0.71 ±0.01	0.98 ±0.00	0.98 ±0.00	0.99 ±0.00
Prevention (all)	0.51 ±0.01	0.71 ±0.01	0.95 ±0.00	0.95 ±0.00	0.96 ±0.00
Prevention (high-impact)	0.00‡	0.93 ±0.01	0.95 ±0.01	0.96 ±0.00	0.96 ±0.00
Residual harm / 1000 sessions	169 ±6	102 ±3	18 ±1	16 ±1	16 ±1
False-block rate (%)	0.29 ±0.01	0.29 ±0.01	0.68 ±0.02	1.20 ±0.06	0.81 ±0.03
False containments / 1000 sessions	0.0 ±0.0	0.0 ±0.0	0.0 ±0.0	23.0 ±1.5	4.2 ±0.5
Decision-record completeness	0.60 ±0.01	0.95 ±0.00	0.95 ±0.00	0.95 ±0.00	0.95 ±0.00
Evidence-record completeness	0.60 ±0.01	0.95 ±0.00	0.99 ±0.00	0.99 ±0.00	0.99 ±0.00
Mean time to containment (actions)	n/a	n/a	1.21 ±0.02	1.10 ±0.02	1.11 ±0.02
Mean time to detection (actions)	3.42 ±0.25	0.00 ±0.00	0.07 ±0.01	0.07 ±0.01	0.11 ±0.01

Detection and prevention are fractions of malicious attempts; detection includes in-path blocks (time 0) and attempts stopped inside an already-detected incident. The false-block rate is the share of benign actions denied, including holds that expired or were wrongly refused and actions stopped by a false containment before review lifted it; benign actions stopped inside correctly contained sessions are excluded (about 760–870 per 1000 sessions in the supervised arms). Decision-record completeness counts attempts with a recorded authorization decision: the gateway's in the gated arms, where it equals the routed share, and the content guard's for outbound actions in the baseline. Evidence-record completeness also counts supervisor alerts and attempts stopped by containment. The reviewer judges a containment correct if its session is compromised, so a false alarm that fires before a compromised session's attack begins counts as correct; a separate check puts the resulting undercount of false containments at about 7%. ‡The baseline has no approval path for transfers or escalations. n/a: the arm never contains a session in progress.

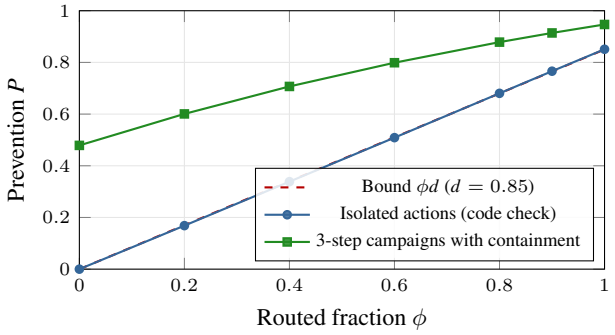


FIGURE 5. Prevention versus the share of actions routed through the gateway. The isolated-action curve reproduces ϕd by construction and serves as a check of the simulation code. When a catch, or an out-of-path alert raised with an assumed probability of 0.6, contains the rest of a three-step campaign, prevention exceeds ϕd: the bound of Eq. (1) applies to each action separately. Simulated; 10 seeds, 95% CIs below 0.006.

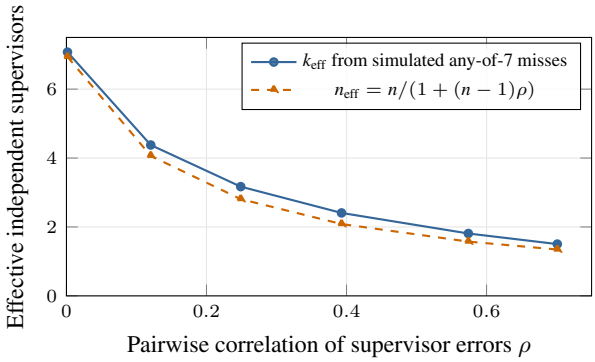


FIGURE 6. Seven supervisors, each with detection rate 0.7, raising an alarm if any one fires. k_{eff} is the number of independent supervisors that would give the same joint miss rate; the design-effect approximation of Eq. (2) slightly underestimates it at every correlation tested. Simulated; one-factor Gaussian error model, 5 seeds of 20,000 trials.

rule. Because $\rho = 0.9$ in Ablation 2 is an assumption, these runs illustrate the consequence of correlated supervisor errors; they do not measure it. When the shared provenance is declared (2a), condition (ii) behaves as intended: agreement among copies of one model never triggers automatic containment, and false containments fall to zero. That result holds by construction, since no benign action in this workload produces deterministic evidence. The cost is a modest rise in residual harm (18 against 16 per thousand sessions), because only deterministic evidence can now contain a campaign. When the correlation is hidden behind declared diversity (2b), the rule is satisfied on paper while its premise fails: false containments rise to 23 per thousand sessions against about 4 for full HACOF, roughly five times as many, and the false-block rate reaches 1.20%. The diversity requirement of Section V.E therefore has to be verified in fact, through the independence evidence that requirement asks for, not accepted from the supervisors' declared provenance.

The coverage bound holds per action, not per campaign. Fig. 5 varies ϕ for a single in-path detector with $d = 0.85$. For isolated actions the simulation computes prevention as the product of routing and detection, so its agreement with ϕd (0.17 at $\phi = 0.2$, 0.85 at $\phi = 1$) confirms the code rather than the bound. The informative curve is the other one. When attacks arrive as three-step campaigns and a catch or an out-of-path alert contains the rest of the session, prevention exceeds ϕd, reaching 0.48 even at $\phi = 0$, where nothing is gated. Its exact height depends on the assumed alert probability, but its direction does not: the bound of Section V.K describes a single action, and out-of-path containment buys campaign-level prevention that no single gate provides.

The effective-supervisor approximation is conservative here. Fig. 6 gives seven supervisors a detection rate of 0.7 each and an alarm if any one fires. With independent errors the joint miss rate is about 2×10^{-4}; as the measured pairwise error correlation rises to 0.70, it climbs to about 0.16, roughly 750 times higher. Converting each simulated joint miss rate into an equivalent number of independent supervisors gives 4.4, 2.4, and 1.5 at error correlations of 0.12, 0.39, and 0.70; the approximation $n/(1 + (n-1)\rho)$ gives 4.1, 2.1, and 1.3.

Across the range tested the approximation errs on the cautious side, the direction a design rule should err in. It was, however, derived for averages and does not cover any-of-n alarms, and under a different error structure the gap could change sign.

What these results do not show. The detectors are Bernoulli draws with assumed rates, not language models; the attacker does not adapt to the supervisors; the workload is one agent type with one profile; human approvers and reviewers are modeled by fixed accuracy rates; and parameter values are assumptions chosen to be plausible, not estimates. The simulation can show that HACOF's parts are logically consistent, how its bounds behave, and which parameters drive its costs. It cannot show that real supervisors reach these rates, which is what the protocol of Sections VII.A–C, run with real agents and real models, has to establish.

E. STAGED DEPLOYMENT

Deployment proceeds in seven phases, summarized in Table 15. Each phase has entry criteria that must hold before it starts and exit criteria, expressed in the metrics of Table 13, that must hold before the next one begins. The numerical thresholds are deliberately left to Phase I: an acceptable false-positive rate for an internal document workflow would be reckless for a payments system, and fixing thresholds after seeing results invites the deployer to set them wherever the results happen to fall.

Phase IV is the phase most likely to be skipped and the one that matters most. It is where the deployer learns what its supervisors flag when nothing is being enforced, and it produces the false-positive evidence on which the decision to enter Phase V depends; a deployment that moves straight from integration to enforcement is setting thresholds by guesswork. Pilots should start in bounded, reversible settings (an internal document workflow, say, before a payments system) and move outward only when a phase's exit criteria are met. Pakistan's planned regulatory sandbox (Section VI.D) is the kind of setting Phases I–IV suit. If a phase fails its own criteria, the deployment steps back one phase rather than forward, and the failure is recorded as a result in its own right under the reporting requirements above.

VIII. LIMITATIONS

Several of these limitations are load-bearing. Readers should weigh them before generalizing the framework.

Single-case-study generalizability. Pakistan is one country with a particular colonial-administrative legal tradition, a particular ICT export profile, and a particular dependence on foreign capital that does not transfer cleanly to an economy with different trade dependencies. We do not test the four-pillar profile against other non-major economies' national policies, so the claim that Pakistan's profile is structural rather than idiosyncratic rests on the resource argument of Section IV, not on cross-country evidence. The four-pillar structure likely generalizes; the specific numbers in Section VI.B do not, and this paper makes no claim that they do.

Policy documents date quickly. Pakistan's National AI Policy was current as of its 2025 publication; funding figures, institutional staffing plans, and even the EU AI Act's implementation timeline described in Section III.A are all subject to revision on a timescale shorter than a journal's publication cycle. A reader checking any cited figure against the live source should expect the figure to have moved since publication, which does not by itself make it wrong.

No primary interviews or surveys were conducted. Every empirical claim in Sections III, IV, and VI rests on published policy documents, funding disclosures, and secondary labor-market data, and Section V is a design proposal built on published technical work. None of it rests on original survey or interview data with regulators, AI lab staff, or displaced Pakistani IT workers. A primary-data study specifically testing whether regulators inside the three major powers themselves perceive the capacity asymmetry described here would be a stronger empirical test than this paper can offer on its own.

Asymmetric data availability biases the comparison itself. The three major powers publish far more granular data about their own regulatory institutions — staffing counts, budget lines, enforcement actions — than most non-major economies publish about theirs. Table 12 is, by necessity, built on richer evidence for the first three columns than the fourth, which means the comparative gap this paper documents may partly measure what gets published more than what exists. This bias most likely understates the non-major-economy column, since evaluators tend to treat missing data as missing capacity, but the paper cannot rule out the reverse.

The four-pillar framework itself has not been empirically validated against governance outcomes. We argue the framework from first principles and illustrate it with one detailed case. It does not test whether a government scoring high on all four pillars actually produces measurably better AI-safety outcomes than one scoring low — that causal link is assumed by analogy to how capacity operates in other regulatory domains; it is not demonstrated with outcome data specific to AI governance. No AI-governance regime has existed long enough to generate the outcome data such a test would require, which is itself part of why no other methodology has closed this gap.

HACOF is tested only in simulation, and its prevention guarantee is only as wide as its enforcement points. Section VII.D reports a prototype of the enforcement plane and a simulation whose supervisor rates are assumed rather than measured; it is not a field evaluation, and the full protocol with real agents and models remains to be run. Even if the architecture performs as designed, monitors will miss behavior that is novel, deliberately concealed, spread thinly across many agents, or simply poorly instrumented. In-path gateways stop only the actions routed through them. A vulnerability in the gateway, an enforcement point someone forgot to place, or a privileged account compromised upstream all bypass Layer 3 without tripping it.

TABLE 15. Staged Deployment Roadmap: Entry Criteria, Activities, and Exit Criteria

Phase	Entry criteria	Key activities	Exit criteria (Table 13 metrics)
I. Governance definition	named accountable officer and policy owner; legal sources for the deployment identified	map Layer 1 obligations; set risk classes; fix per-category thresholds for every metric; define the appeal path and its deadlines	every planned rule has a clause source; thresholds recorded and signed before any test
II. Policy engineering	Phase I signed off	write authorization profiles and boundary rules; build test suites from the ten scenario families	every profile passes its tests; *audit completeness* target met on synthetic decisions
III. Technical integration	profiles approved	deploy identity, gateways, transaction holds, and the audit plane; connect telemetry	every governed action produces a record; *audit completeness* met on live traffic; gateway fails closed in outage drills
IV. Supervisory monitoring (observe-only)	Phase III exit met	run Agents A–G without enforcement; build per-agent baselines; seed known violations	*false-positive rate*, *violation detection rate*, and *mean time to detection* measured per risk category with uncertainty intervals; baselines approved
V. Controlled enforcement	Phase IV evidence meets the Phase I false-positive thresholds	switch on automated denial only for scenarios that passed testing; route everything ambiguous to people	*prevention effectiveness*, *mean time to containment*, *residual harm*, and *review and appeal outcomes* within thresholds
VI. Independent assurance	Phase V stable over the agreed observation period	red-team exercises against agents and supervisors; privacy impact review; security audit; measurement of supervisor reliability and of ρ (Section V.K)	external auditor's report filed; *privacy impact* within limits; supervisor diversity confirmed by ablation
VII. Continuous improvement	Phase VI report accepted	approved, regression-tested policy and baseline updates; periodic re-assurance	no update raises the *false-positive rate* or lowers *violation detection rate* beyond threshold; *recovery time* tracked

The supervisors carry their own weaknesses and costs. Supervisory agents built on language models inherit those models' failure modes, and independence engineered on paper may still leave shared blind spots in practice [65]. An adversary who learns how the monitors work can tune an attack to them. Continuous oversight also costs compute and adds latency to every gated action, and the telemetry it requires is itself a store of sensitive data that must be protected and eventually deleted. For a small deployer in a low-income economy, these costs may be large enough to tempt partial adoption, which risks leaving the paperwork of HACOF without the protection.

Some disagreements are not engineering problems. What counts as harm, how much risk is acceptable, and whose authority is legitimate are contested questions that no architecture settles; HACOF assumes Layer 1 has answered them through lawful institutions, and where those institutions are weak or captured the architecture enforces whatever they decide. Deployments that cross organizations or borders add coordination problems that this paper names but does not solve: interoperable profile formats, allocation of responsibility, cross-border evidence sharing, and outright conflicts between national laws.

English-language and Western-source bias in the evidence base. Pakistan's own Urdu-language policy debate, parliamentary committee discussion, and domestic tech-press coverage of the National AI Policy are not represented in this paper's evidence base, which draws overwhelmingly on English-language government documents, international reporting, and donor and multilateral publications. A debate conducted substantially in Urdu inside Pakistan's own policy community may contain objections, nuances, or planned revisions that English-language sourcing cannot surface.

IX. CONCLUSION

HACOF assembles legal authority, machine-readable policy, preventive controls placed outside the model, supervisors kept independent of the agents they watch, live monitoring, early containment, human review, and continuous improvement into one architecture. The reason to assemble them is to move governance off the page and into the systems agents run on: a policy document beside a deployment changes nothing an agent can do, while a gate in front of it does. Under HACOF, an agent's authority is sized to its approved purpose, its actions are watched by mechanisms proportionate to the risk, violations meet responses agreed before they happen, and the supervisors themselves stay auditable by, and answerable to, people with legitimate authority. Instructing a model to behave well is the weakest version of this. The stronger version is an environment that makes good behavior the default, blocks forbidden actions wherever a gate can reach them, catches and contains harm that gets past the gates, and keeps a record from which failures of governance itself can be investigated and repaired.

Meaningful human control over AI is not a property a law can declare into existence. It requires boundary-setting authority backed by real enforcement leverage, incentive-steering capital large enough to move a market, HITL regulatory institutions staffed with people who can keep pace with deployment cycles, and algorithmic auditing access to the models being governed. We have argued that all four currently concentrate inside three jurisdictions, and that a government outside them cannot close the gap by legislating harder. That holds for Pakistan, examined here in detail, and by structural extension for most of the more than 70 governments that have issued a national AI strategy. Meaningful participation for a non-major economy requires, at minimum, a market-access

or coalition-based lever strong enough to make boundary-setting enforceable against foreign vendors, and a funding commitment that matters at least regionally. It also needs a technical staffing pipeline built for AI oversight, not borrowed from general ICT regulation, and an audit-access arrangement secured by negotiation or treaty, so that oversight no longer rests on vendor self-reporting.

Capacity at the level of the state is necessary but not sufficient. The second half of the argument is operational. HACOF shows what has to exist at the point where an agent acts: authority traced to law, enforcement points the governed model cannot reach, supervisors that are themselves supervised, and monitoring confined to AI activity rather than people. Its mapping onto the pillars yields a practical asymmetry. A low-capacity state cannot audit a foreign model's weights, but it can require domestic deployers to keep an audit trail it is able to read, which is a far smaller technical task. That does not close the gap this paper documents; it narrows the part of it a government can act on this budget cycle.

The gaps are not equally pressing, and the agenda below takes them in order.

Audit-access mechanisms for non-major economies are the most urgent gap. No treaty framework, mutual-recognition arrangement, or technical standard currently exists for a government outside the three major powers to obtain independent, verifiable access to a foreign-hosted model's behavior. Nothing here needs new money so much as a protocol that does not yet exist: a negotiated technical-access protocol that a coalition of non-major economies could plausibly demand jointly even without any single member having individual leverage. International financial auditing offers a rough structural precedent worth studying, though not copying wholesale: authorities responsible for globally active banks rely on cross-border cooperation arrangements and shared standards because no single national authority can resolve such a bank unilaterally [79]. The analogy is imperfect, because banks are heavily regulated at origin in a way frontier AI labs currently are not, but the underlying mechanism, pooled technical standards substituting for individual enforcement power, is the right shape of solution to study first.

Coalition-based boundary-setting leverage is a different kind of problem, and treating it like the audit-access gap would misdiagnose both. A single mid-sized economy's market is not large enough to compel vendor compliance, but a bloc of such economies negotiating jointly, on the model of regional trade blocs that already pool market access for other purposes, plausibly is. This requires institution-building that outlasts any single government's term, coordination costs that regional organizations historically struggle to sustain, and a shared technical baseline for what "compliance" even means across member states with different legal traditions. It is a harder, slower project than the audit-access mechanism above, and that is why it should not be allowed to become the default first target simply because it sounds more comprehensive.

A validated empirical test of the four-pillar framework against actual governance outcomes must come before any policy recommendation that claims a given capacity investment will causally improve AI-safety outcomes, not merely the framework's own capacity score. Until it exists, this framework should be read as a diagnostic structure whose predictions are not yet certified. The same discipline applies to HACOF: the protocol of Section VII, and in particular its ablation testing whether seven supervisors built on one base model behave as one, should be run before any regulator writes HACOF-style requirements into binding rules.

The remaining items — primary survey data on regulator and displaced-worker perspectives, country comparisons beyond the single Pakistani case, and interoperable formats for authorization profiles and audit records across jurisdictions — matter, but they extend the evidence base, and they can proceed in parallel with the three items above; they need not wait for them.

The guiding principle of HACOF is the one we close on: AI should be developed and operated for the benefit of humanity, under enforceable rules that people define, with continuous technical oversight and accountable authority over both the systems being governed and the systems that govern them.

ACKNOWLEDGMENTS

This work received no external funding or institutional support.

The text of Sections I–IX was drafted with the assistance of Claude (Anthropic), an artificial intelligence system, which provided literature research assistance, drafting assistance, fact-checking assistance, and assistance in writing the prototype and simulation code of Section VII-D under the direction, review, and final verification of the author, who is fully accountable for all content, citations, and claims in this article. No AI system is credited as an author.

REFERENCES

[1] Ministry of Information Technology and Telecommunication, Government of Pakistan, "National Artificial Intelligence Policy 2025," Government of Pakistan. [Online]. Available: https://moitt.gov.pk/SiteImage/Policies/National%20AI%20Policy.pdf, 2025, approved by the Federal Cabinet, July 30, 2025. Accessed: Oct. 11, 2026.

[2] Dawn, "Cabinet Approves National AI Policy," Dawn. [Online]. Available: https://www.dawn.com/news/1927634, 2025, published July 2025. Accessed Oct. 2026.

[3] OECD.AI, "OECD.AI Policy Observatory: National AI Strategies," OECD.AI. [Online]. Available: https://oecd.ai/en/dashboards, 2026, tracking 70+ published national AI strategies worldwide. Accessed Oct. 2026.

[4] Epoch AI, "The Geopolitics of AI: Data and Research," Epoch AI. [Online]. Available: https://epoch.ai/topics/geopolitics, 2026, five hyperscalers hold approx. 71% of cumulative world AI compute (Q4 2025). Accessed Oct. 2026.

[5] S. Altman, G. Brockman, and I. Sutskever, "Governance of Superintelligence," OpenAI Blog. [Online]. Available: https://openai.com/index/governance-of-superintelligence/, 2023, published May 22, 2023. Accessed Oct. 2026.

[6] Center for AI Safety, "Statement on AI Risk," safe.ai. [Online]. Available: https://www.safe.ai/work/statement-on-ai-risk, 2023, published May 30, 2023, with 350+ signatories at launch. Accessed Oct. 2026.

[7] H. Belfield, "Domestic Frontier AI Regulation, an IAEA for AI, an NPT for AI, and a US-Led Allied Public-Private Partnership for AI: Four

Institutions for Governing and Developing Frontier AI," arXiv preprint arXiv:2507.06379, 2025, submitted July 8, 2025.

[8] European Parliament and Council of the European Union, "Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)," Official Journal of the European Union. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2024/1689, 2024, published July 12, 2024; entered into force Aug. 1, 2024. Accessed Oct. 2026.

[9] Executive Office of the President (Trump), "Executive Order 14365: Ensuring a National Policy Framework for Artificial Intelligence," Federal Register. [Online]. Available: https://www.federalregister.gov/d/2025-23092, 2025, 90 FR 58499. Issued Dec. 11, 2025. Accessed Oct. 2026.

[10] Cyberspace Administration of China, National Development and Reform Commission, Ministry of Education, Ministry of Science and Technology, Ministry of Industry and Information Technology, Ministry of Public Security, and National Radio and Television Administration, "Interim Measures for the Administration of Generative Artificial Intelligence Services," Cyberspace Administration of China. [Online]. Available: https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm, 2023, issued July 13, 2023; effective Aug. 15, 2023. Accessed Oct. 2026.

[11] Y. Bai, S. Kadavath, S. Kundu, A. Askell, J. Kernion, A. Jones, A. Chen, A. Goldie, A. Mirhoseini, C. McKinnon, C. Chen, C. Olsson, C. Olah, D. Hernandez, D. Drain, D. Ganguli, D. Li, E. Tran-Johnson, E. Perez, J. Kerr, J. Mueller, J. Ladish, J. Landau, K. Ndousse, K. Lukosuite, L. Lovitt, M. Sellitto, N. Elhage, N. Schiefer, N. Mercado, N. DasSarma, R. Lasenby, R. Larson, S. Ringer, S. Johnston, S. Kravec, S. El Showk, S. Fort, T. Lanham, T. Telleen-Lawton, T. Conerly, T. Henighan, T. Hume, S. R. Bowman, Z. Hatfield-Dodds, B. Mann, D. Amodei, N. Joseph, S. McCandlish, T. Brown, and J. Kaplan, "Constitutional AI: Harmlessness from AI Feedback," *arXiv preprint arXiv:2212.08073*, 2022, submitted Dec. 15, 2022.

[12] D. Amodei, "Prepared Remarks, UK AI Safety Summit," Anthropic. [Online]. Available: https://www.anthropic.com/news/uk-ai-safety-summit, 2023, bletchley Park, Nov. 1, 2023. Accessed Oct. 2026.

[13] I. D. Raji, A. Smart, R. N. White, M. Mitchell, T. Gebru, B. Hutchinson, J. Smith-Loud, D. Theron, and P. Barnes, "Closing the AI Accountability Gap: Defining an End-to-End Framework for Internal Algorithmic Auditing," in *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency*, 2020, pp. 33–44.

[14] J. Buolamwini and T. Gebru, "Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification," in *Proceedings of Machine Learning Research*, vol. 81, 2018, pp. 77–91, conference on Fairness, Accountability and Transparency (FAT* 2018).

[15] S. Wachter, B. Mittelstadt, and C. Russell, "Bias Preservation in Machine Learning: The Legality of Fairness Metrics Under EU Non-Discrimination Law," *West Virginia Law Review*, vol. 123, no. 3, pp. 735–790, 2021.

[16] M. Mitchell, S. Wu, A. Zaldivar, P. Barnes, L. Vasserman, B. Hutchinson, E. Spitzer, I. D. Raji, and T. Gebru, "Model Cards for Model Reporting," in *Proceedings of the Conference on Fairness, Accountability, and Transparency (FAT* '19)*, 2019, pp. 220–229.

[17] African Union, "Continental Artificial Intelligence Strategy," African Union. [Online]. Available: https://au.int/en/pressreleases/20240617/african-ministers-adopt-landmark-continental-artificial-intelligence-strategy, 2024, adopted by the AU Executive Council, 45th Ordinary Session, July 18-19, 2024, Accra, Ghana. 2025-2030 implementation period.

[18] UNESCO, "Recommendation on the Ethics of Artificial Intelligence," UNESCO. [Online]. Available: https://www.unesco.org/en/legal-affairs/recommendation-ethics-artificial-intelligence, 2021, adopted by acclamation by all 193 Member States, Nov. 23, 2021. Explicitly non-binding.

[19] OECD / Global Partnership on AI, "Global Partnership on Artificial Intelligence: Council Summary Record," OECD.AI. [Online]. Available: https://wp.oecd.ai/app/uploads/2025/01/GPAI-Council_Summary-record_4-Dec-2024.pdf, 2024, merged with OECD, July 2024; 44 members plus the EU. Voluntary, non-binding partnership. Accessed Oct. 2026.

[20] C. Arun, "AI and the Global South: Designing for Other Worlds," in *The Oxford Handbook of Ethics of AI*, M. D. Dubber, F. Pasquale, and S. Das, Eds. Oxford University Press, 2020, pp. 588–606.

[21] S. Mhlambi, "From Rationality to Relationality: Ubuntu as an Ethical and Human Rights Framework for Artificial Intelligence Governance," Carr Center for Human Rights Policy, Harvard Kennedy School, Tech. Rep. 2020-009, 2020.

[22] G. Ayana, K. Dese, H. D. Nemomssa, B. Habtamu, B. Mellado, K. Badu, E. Yamba, S. L. Faye, M. Ondua, D. Nsagha, D. Nkweteyim, and J. D. Kong, "Decolonizing Global AI Governance: Assessment of the State of Decolonized AI Governance in Sub-Saharan Africa," *Royal Society Open Science*, vol. 11, no. 8, p. 231994, 2024.

[23] R. Greenblatt, B. Shlegeris, K. Sachan, and F. Roger, "AI Control: Improving Safety Despite Intentional Subversion," in *Proc. 41st Int. Conf. Mach. Learn. (ICML)*, ser. Proceedings of Machine Learning Research, vol. 235, 2024, pp. 16 295–16 336, arXiv:2312.06942. Accessed: Oct. 11, 2026. [Online]. Available: https://proceedings.mlr.press/v235/greenblatt24a.html

[24] Y. Shavit, S. Agarwal, M. Brundage, S. Adler, C. O'Keefe, R. Campbell, T. Lee, P. Mishkin, T. Eloundou, A. Hickey, K. Slama, L. Ahmad, P. McMillan, A. Beutel, A. Passos, and D. G. Robinson, "Practices for Governing Agentic AI Systems," OpenAI, White Paper, Dec. 2023, accessed: Oct. 11, 2026. [Online]. Available: https://cdn.openai.com/papers/practices-for-governing-agentic-ai-systems.pdf

[25] A. Chan, C. Ezell, M. Kaufmann, K. Wei, L. Hammond, H. Bradley, E. Bluemke, N. Rajkumar, D. Krueger, N. Kolt, L. Heim, and M. Anderljung, "Visibility into AI Agents," in *Proc. 2024 ACM Conf. Fairness, Accountability, and Transparency (FAccT)*, 2024, pp. 958–973.

[26] N. Kolt, "Governing AI Agents," *Notre Dame Law Review*, vol. 101, pp. 335–386, 2026, arXiv:2501.07913. Accessed: Oct. 11, 2026. [Online]. Available: https://ndlawreview.org/wp-content/uploads/2026/08/Kolt_101.335.pdf

[27] H. Inan, K. Upasani, J. Chi, R. Rungta, K. Iyer, Y. Mao, M. Tontchev, Q. Hu, B. Fuller, D. Testuggine, and M. Khabsa, "Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations," arXiv:2312.06674, 2023, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2312.06674

[28] M. Sharma, M. Tong, J. Mu, J. Wei, J. Kruthoff, S. Goodfriend, E. Ong, A. Peng, R. Agarwal, C. Anil, A. Askell, N. Bailey, J. Benton, E. Bluemke, S. R. Bowman, E. Christiansen, H. Cunningham, A. Dau, A. Gopal, R. Gilson, L. Graham, L. Howard, N. Kalra, T. Lee, K. Lin, P. Lofgren, F. Mosconi, C. O'Hara, C. Olsson, L. Petrini, S. Rajani, N. Saxena, A. Silverstein, T. Singh, T. Sumers, L. Tang, K. K. Troy, C. Weisser, R. Zhong, G. Zhou, J. Leike, J. Kaplan, and E. Perez, "Constitutional Classifiers: Defending against Universal Jailbreaks across Thousands of Hours of Red Teaming," arXiv:2501.18837, 2025, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2501.18837

[29] T. Rebedea, R. Dinu, M. N. Sreedhar, C. Parisien, and J. Cohen, "NeMo Guardrails: A Toolkit for Controllable and Safe LLM Applications with Programmable Rails," in *Proc. 2023 Conf. Empirical Methods in Natural Language Processing: System Demonstrations*. Singapore: Association for Computational Linguistics, 2023, pp. 431–445.

[30] Z. Xiang, L. Zheng, Y. Li, J. Hong, Q. Li, H. Xie, J. Zhang, Z. Xiong, C. Xie, C. Yang, D. Song, and B. Li, "GuardAgent: Safeguard LLM Agents via Knowledge-Enabled Reasoning," in *Proc. 42nd Int. Conf. Mach. Learn. (ICML)*, ser. Proceedings of Machine Learning Research, vol. 267, 2025, pp. 68 316–68 342, arXiv:2406.09187. Accessed: Oct. 11, 2026. [Online]. Available: https://proceedings.mlr.press/v267/xiang25a.html

[31] Z. Chen, M. Kang, and B. Li, "ShieldAgent: Shielding Agents via Verifiable Safety Policy Reasoning," in *Proc. 42nd Int. Conf. Mach. Learn. (ICML)*, ser. Proceedings of Machine Learning Research, vol. 267, 2025, pp. 8313–8344, arXiv:2503.22738. Accessed: Oct. 11, 2026. [Online]. Available: https://proceedings.mlr.press/v267/chen25ae.html

[32] H. Wang, C. M. Poskitt, and J. Sun, "AgentSpec: Customizable Runtime Enforcement for Safe and Reliable LLM Agents," in *Proc. IEEE/ACM 48th Int. Conf. Softw. Eng. (ICSE)*, 2026, pp. 2938–2950.

[33] D. Gosmar and D. A. Dahl, "Sentinel Agents for Secure and Trustworthy Agentic AI in Multi-Agent Systems," arXiv:2509.14956, 2025, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2509.14956

[34] S. Gaurav, J. Heikkonen, and J. Chaudhary, "Governance-as-a-Service: A Multi-Agent Framework for AI System Compliance and Policy Enforcement," arXiv:2508.18765, 2025, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2508.18765

[35] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo, "MI9: An Integrated Runtime Governance Framework for Agentic AI," arXiv:2508.03858, 2025, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2508.03858

[36] M. Shamsujjoha, Q. Lu, D. Zhao, and L. Zhu, "Swiss Cheese Model for AI Safety: A Taxonomy and Reference Architecture for Multi-Layered Guardrails of Foundation Model Based Agents," in *Proc. 2025 IEEE 22nd Int. Conf. Softw. Archit. (ICSA)*, 2025, pp. 37–48.

[37] C. Koch, "From Governance Norms to Enforceable Controls: A Layered Translation Method for Runtime Guardrails in Agentic AI,"

arXiv:2604.05229, 2026, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2604.05229

[38] Infocomm Media Development Authority, "Model AI Governance Framework for Agentic AI, Version 1.5," Infocomm Media Development Authority (IMDA), Singapore, Tech. Rep., May 2026, published May 20, 2026; updated Jun. 5, 2026. Accessed: Oct. 11, 2026. [Online]. Available: https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf

[39] L. Sha, "Using Simplicity to Control Complexity," *IEEE Softw.*, vol. 18, no. 4, pp. 20–28, 2001.

[40] M. Alshiekh, R. Bloem, R. Ehlers, B. Könighofer, S. Niekum, and U. Topcu, "Safe Reinforcement Learning via Shielding," in *Proc. AAAI Conf. Artif. Intell.*, vol. 32, 2018.

[41] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," in *Proc. 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, 2023, pp. 79–90.

[42] European Parliament and Council of the European Union, "Regulation (EU) 2026/1744 of the European Parliament and of the Council of 8 July 2026 Amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as Regards the Simplification of the Implementation of Harmonised Rules on Artificial Intelligence (Digital Omnibus on AI)," Official Journal of the European Union, L series, Jul. 24, 2026, 2026, accessed: Oct. 11, 2026. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2026/1744/oj

[43] Executive Office of the President (Biden), "Executive Order 14110: Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence," Federal Register. [Online]. Available: https://www.federalregister.gov/documents/2023/11/01/2023-24283, 2023, issued Oct. 30, 2023; revoked Jan. 20, 2025. Accessed Oct. 2026.

[44] Executive Office of the President (Trump), "Executive Order 14179: Removing Barriers to American Leadership in Artificial Intelligence," Federal Register. [Online]. Available: https://www.federalregister.gov/documents/2025/01/31/2025-02172, 2025, issued Jan. 23, 2025. Accessed Oct. 2026.

[45] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST, Tech. Rep. NIST AI 100-1, 2023, published Jan. 2023, developed with 240+ contributing organizations. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf

[46] State Council of the People's Republic of China, "A Next Generation Artificial Intelligence Development Plan (State Council Document [2017] No. 35)," Released July 20, 2017. English translation by G. Webster, R. Creemers, E. Kania, and P. Triolo, DigiChina, Stanford University. [Online]. Available: https://digichina.stanford.edu/work/full-translation-chinas-new-generation-artificial-intelligence-development-plan-2017/, 2017, section IV(1): use existing policy input funds to support AI programs; plan multiple-channel financial input by government and markets. Accessed Oct. 2026.

[47] State Bank of Pakistan, "Exports and Imports of Goods & Services (Million US $)," 2026, row 9, Telecommunications, Computer, and Information Services: 3,814 (FY25), 4,600 (FY26). Rolling table, updated monthly. Accessed Oct. 14, 2026. [Online]. Available: https://www.sbp.org.pk/ecodata/ExportsImports-Goods.pdf

[48] 117th United States Congress, "CHIPS and Science Act of 2022," H.R.4346. [Online]. Available: https://www.congress.gov/bill/117th-congress/house-bill/4346, 2022, approx. $280 billion over 10 years; $52.7B semiconductor manufacturing/R&D, $20B NSF Technology, Innovation and Partnerships directorate covering AI among other critical technologies.

[49] European Commission, "AI Innovation Package," European Commission Digital Strategy. [Online]. Available: https://digital-strategy.ec.europa.eu/en/factpages/ai-innovation-package, 2024, announced Jan. 2024; approx. EUR 4 billion mobilized through 2027 via Horizon Europe and the Digital Europe Programme.

[50] J. Huang, "The AI Five-Layer Cake," NVIDIA Blog. [Online], 2026, bylined essay, Mar. 10, 2026; the framing was also used at Davos (Jan. 2026). Available: https://blogs.nvidia.com/blog/ai-5-layer-cake/. Accessed Oct. 2026.

[51] CompaniesMarketCap, "NVIDIA (NVDA) Market Capitalization," 2026, $144.00 billion at end-2019; $5.507 trillion at the Oct. 13, 2026 close (Nasdaq); first passed $5.5 trillion intraday on May 13, 2026. Accessed Oct. 14, 2026. [Online]. Available: https://companiesmarketcap.com/nvidia/marketcap/

[52] Agence Europe, "40 of 140 Staff Members of European Commission's AI Office Work on AI Safety," Agence Europe Bulletin. [Online]. Available: https://agenceurope.eu/en/bulletin/article/13883/11/40-of-140-staff-members-of-european-commissions-ai-office-work-on-ai-safety, 2026, june 2026, citing a written parliamentary answer from Executive Vice-President Henna Virkkunen. Accessed Oct. 2026.

[53] Stanford Institute for Human-Centered Artificial Intelligence, "The 2026 AI Index Report," Stanford HAI, Tech. Rep., 2026, chapter 1: Research and Development. AI research talent concentration as a proxy indicator. [Online]. Available: https://hai.stanford.edu/ai-index/2026-ai-index-report

[54] O. Pfungst, *Clever Hans (The Horse of Mr. Von Osten): A Contribution to Experimental Animal and Human Psychology*. Henry Holt and Company, 1911, english translation of the 1907 German original investigation.

[55] J. Egan and L. Heim, "Oversight for Frontier AI Through a Know-Your-Customer Scheme for Compute Providers," Centre for the Governance of AI. [Online]. Available: https://www.governance.ai/research-paper/oversight-for-frontier-ai-through-kyc-scheme-for-compute-providers, 2023, published Oct. 25, 2023.

[56] C. Salvador, "Certified Safe: A Schematic for Approval Regulation of Frontier AI," arXiv preprint arXiv:2408.06210, 2024, submitted Aug. 12, 2024.

[57] United Nations Framework Convention on Climate Change, "Paris Agreement, Article 10 (Technology Development and Transfer)," UNFCCC. [Online]. Available: https://unfccc.int/sites/default/files/english_paris_agreement.pdf, 2015, building on UNFCCC Art. 4(5); operationalized through the UNFCCC Technology Mechanism. Accessed Oct. 2026.

[58] R. Wyden and C. Booker, "Algorithmic Accountability Act of 2023," S.2892, 118th Congress. [Online]. Available: https://www.congress.gov/bill/118th-congress/senate-bill/2892/text, 2023, introduced Sept. 21, 2023; reintroduced in the 119th Congress (2025). Domestic scope.

[59] OWASP GenAI Security Project, "LLM06:2025 Excessive Agency, in OWASP Top 10 for LLM Applications 2025," OWASP Foundation, Nov. 2024, accessed: Oct. 11, 2026. [Online]. Available: https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

[60] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST Special Publication 800-207, Aug. 2020.

[61] J. H. Saltzer and M. D. Schroeder, "The Protection of Information in Computer Systems," *Proc. IEEE*, vol. 63, no. 9, pp. 1278–1308, 1975.

[62] ISO/IEC, "ISO/IEC 42001:2023 – Information Technology – Artificial Intelligence – Management System," International Organization for Standardization / International Electrotechnical Commission, Geneva, Edition 1, Dec. 2023, accessed: Oct. 11, 2026. [Online]. Available: https://www.iso.org/standard/42001

[63] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST AI 600-1, Jul. 2024.

[64] E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke, and A. Beutel, "The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions," arXiv:2404.13208, 2024, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2404.13208

[65] E. M. Kim, A. Garg, K. Peng, and N. Garg, "Correlated Errors in Large Language Models," in *Proc. 42nd Int. Conf. Mach. Learn. (ICML)*, ser. Proceedings of Machine Learning Research, vol. 267, 2025, pp. 30 038–30 066, arXiv:2506.07962. Accessed: Oct. 11, 2026. [Online]. Available: https://proceedings.mlr.press/v267/kim25e.html

[66] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, "Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST Special Publication 800-61 Rev. 3, Apr. 2025.

[67] Office of Management and Budget, "Accelerating Federal Use of AI through Innovation, Governance, and Public Trust," Memorandum M-25-21, Executive Office of the President, Washington, DC, USA, Apr. 3, 2025, Apr. 2025, accessed: Oct. 11, 2026. [Online]. Available: https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf

[68] M. Brundage, S. Avin, J. Wang, H. Belfield, G. Krueger, G. Hadfield, H. Khlaaf, J. Yang, H. Toner, R. Fong, T. Maharaj, P. W. Koh, S. Hooker, J. Leung, A. Trask, E. Bluemke, J. Lebensold, C. O'Keefe, M. Koren, T. Ryffel, J. B. Rubinovitz, T. Besiroglu, F. Carugati, J. Clark, P. Eckersley, S. de Haas, M. Johnson, B. Laurie, A. Ingerman, I. Krawczuk, A. Askell,

R. Cammarota, A. Lohn, D. Krueger, C. Stix, P. Henderson, L. Graham, C. Prunkl, B. Martin, E. Seger, N. Zilberman, S. Ó. hÉigeartaigh, F. Kroeger, G. Sastry, R. Kagan, A. Weller, B. Tse, E. Barnes, A. Dafoe, P. Scharre, A. Herbert-Voss, M. Rasser, S. Sodhani, C. Flynn, T. K. Gilbert, L. Dyer, S. Khan, Y. Bengio, and M. Anderljung, "Toward Trustworthy AI Development: Mechanisms for Supporting Verifiable Claims," arXiv:2004.07213, 2020, accessed: Oct. 11, 2026. [Online]. Available: https://arxiv.org/abs/2004.07213

[69] European Parliament and Council of the European Union, "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the Protection of Natural Persons with Regard to the Processing of Personal Data and on the Free Movement of Such Data (General Data Protection Regulation)," Official Journal of the European Union, L 119, May 4, 2016, 2016, accessed: Oct. 11, 2026. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2016/679/oj

[70] R. Parasuraman and D. H. Manzey, "Complacency and Bias in Human Use of Automation: An Attentional Integration," *Human Factors*, vol. 52, no. 3, pp. 381–410, 2010.

[71] Associated Press of Pakistan, "Pakistan Plans Rs283bn National AI Ecosystem Programme," Associated Press of Pakistan. [Online]. Available: https://www.app.com.pk/national/pakistan-plans-rs283bn-national-ai-ecosystem-programme, 2026, june 22, 2026; programme planned for 2026–2031, initial allocation proposed. Accessed Oct. 2026.

[72] International Monetary Fund, "GDP, Current Prices (Billions of U.S. Dollars): Pakistan," 2026, iMF DataMapper, World Economic Outlook data: $408.2 billion (2025), $450.1 billion (2026 projection). Accessed Oct. 14, 2026. [Online]. Available: https://www.imf.org/external/datamapper/NGDPD@WEO/PAK

[73] SiliconANGLE, "OpenAI Just Closed a Record-Breaking $122B Funding Round That Brings Its Value to $852B," 2026, mar. 31, 2026; reports OpenAI's announcement (openai.com/index/accelerating-the-next-phase-ai/). Accessed Oct. 2026. [Online]. Available: https://siliconangle.com/2026/03/31/openai-just-closed-record-breaking-122b-funding-round-brings-value-852b/

[74] Anthropic, "Anthropic Raises $65 Billion in Series H Funding," 2026, may 28, 2026; $965 billion post-money valuation. Accessed Oct. 2026. [Online]. Available: https://www.anthropic.com/news/series-h

[75] Dawn, "Islamabad Schools, Colleges to Teach AI from Next Academic Session," Dawn. [Online]. Available: https://www.dawn.com/news/1969030, 2026, jan. 26, 2026. Accessed Oct. 2026.

[76] E. Brynjolfsson, B. Chandar, and R. Chen, "Canaries in the Coal Mine? Six Facts About the Recent Employment Effects of Artificial Intelligence," Stanford Digital Economy Lab, Tech. Rep., 2025. [Online]. Available: https://digitaleconomy.stanford.edu/publication/canaries-in-the-coal-mine-six-facts-about-the-recent-employment-effects-of-artificial-intelligence/

[77] Office of Management and Budget, "Driving Efficient Acquisition of Artificial Intelligence in Government," Memorandum M-25-22, Executive Office of the President, Washington, DC, USA, Apr. 3, 2025, Apr. 2025, accessed: Oct. 11, 2026. [Online]. Available: https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-22-Driving-Efficient-Acquisition-of-Artificial-Intelligence-in-Government.pdf

[78] S. Khan and S. H. Khan, "Data Protection & Privacy 2026: Pakistan," Chambers and Partners Global Practice Guides (S.U.Khan Associates), last updated Mar. 10, 2026, Mar. 2026, accessed: Oct. 11, 2026. [Online]. Available: https://practiceguides.chambers.com/practice-guides/data-protection-privacy-2026/pakistan

[79] Basel Committee on Banking Supervision, "Report and Recommendations of the Cross-Border Bank Resolution Group," Bank for International Settlements, Tech. Rep., 2010, mar. 2010. Accessed Oct. 2026. [Online]. Available: https://www.bis.org/publications/201003-guidelines-report-and-recommendations-cross-border-bank-resolution-group.pdf